



Federal Office
for Information Security

Technical Guideline BSI TR-03179-2: Central Bank Digital Currency

Part 2: Requirements on frontend systems



Document history

<i>Version</i>	<i>Date</i>	<i>Editor</i>	<i>Description</i>
0.1	July 2024		First complete draft
1.0	January 2025		First public version

Table 1: Document history

Table of Contents

1	Introduction.....	6
1.1	Subject and Purpose of the Technical Guideline	6
1.2	Scope.....	6
1.3	Overview of the Technical Guideline	6
1.4	Terms & Explanations	7
1.5	Conditions and alliance with other publications.....	7
2	Overview of security requirements.....	9
2.1	Life cycle, entities and components	9
2.2	General considerations	9
2.2.1	Delegation of responsibility.....	9
2.2.2	Crypto-agility.....	10
2.2.3	Use cases.....	10
2.2.4	Wallets	11
2.2.5	Other technical design choices.....	15
2.3	Security problem definition	17
2.3.1	Organisational Security Policies	17
2.3.2	Assumptions.....	17
3	Wallet.....	18
3.1	General functions.....	18
3.1.1	Objectives	18
3.1.2	Threats	18
3.1.3	Requirements.....	18
3.1.4	Rationale	20
3.2	Hardware and interfaces	21
3.2.1	Objectives	22
3.2.2	Threats	22
3.2.3	Requirements.....	22
3.2.4	Rationale	23
3.3	Authentication and authorisation	23
3.3.1	Objectives	24
3.3.2	Threats	24
3.3.3	Requirements.....	24
3.3.4	Rationale	25
3.4	Personalisation.....	26
3.4.1	Objectives	26
3.4.2	Threats	26
3.4.3	Requirements.....	27
3.4.4	Rationale	27
3.5	Disabling and blocking	27

3.5.1	Objectives	28
3.5.2	Threats	28
3.5.3	Requirements.....	28
3.5.4	Rationale	29
3.6	Synchronisation with the CBDC backend system.....	30
3.6.1	Objectives	30
3.6.2	Threats	31
3.6.3	Requirements.....	31
3.6.4	Rationale	32
3.7	Update.....	33
3.7.1	Objectives	33
3.7.2	Threats	33
3.7.3	Requirements.....	34
3.7.4	Rationale	35
3.8	Wallet Accounting	36
3.8.1	Objectives	37
3.8.2	Threats	37
3.8.3	Requirements.....	37
3.8.4	Rationale	38
3.9	Wallet provider	39
3.9.1	Objectives	39
3.9.2	Threats	39
3.9.3	Requirements.....	39
3.9.4	Rationale	40
4	Transactions.....	42
4.1	Payment	42
4.1.1	Objectives	42
4.1.2	Threats	43
4.1.3	Requirements.....	43
4.1.4	Rationale	44
4.2	Validity check.....	46
4.2.1	Objectives	46
4.2.2	Threats	47
4.2.3	Requirements.....	47
4.2.4	Rationale	47
5	Conclusion.....	49
	Annex A: Comparison of CBDC and cash.....	50
	Glossary.....	52
	List of abbreviations	55
	Bibliography	56

1 Introduction

1.1 Subject and Purpose of the Technical Guideline

This Technical Guideline (in German Technische Richtlinie, TR) covers Central Bank Digital Currencies (CBDCs). CBDCs are electronic forms of money that are issued and managed by an official body (e. g. a central bank) in the same way as cash. They must not be confused with so-called ‘cryptocurrencies’ which are not within the scope of this TR.

CBDCs cannot replace all properties of cash. But it can complement in places where it provides additional functionality and facilitates further use cases. Annex A ‘Comparison of CBDC and cash’ offers a comparison of CBDC and cash.

The purpose of this Technical Guideline is to define a standard that specifies an appropriate level of IT security for the use of CBDC. It is aimed at both public bodies and private developers of applications for CBDC.

This (second) part of the TR refers to the frontend systems supporting the CBDC ecosystem. CBDCs are stored in so called wallets, from which the possible transactions are also started.

The TR therefore focuses on the requirements for the secure design of the frontend in line with the security by design idea and addresses the issuers of the wallets here and then on the processes that are important to assist the end-user in carrying out the corresponding actions. The corresponding requirements of the central backend system are taken into account in the TR Backend [1].

To achieve these goals, targets are defined, threats addressed, and potential requirements that protect and mitigate threats are defined.

The Technical Guideline is aimed primarily at manufacturers of wallets and wallet providers. In particular, it addresses the parts of the companies that accompany the implementation of IT security-related functions on the basis of the processual framework conditions.

1.2 Scope

The management of CBDCs will take place in different types of wallets and wallet applications. The tasks of the wallets include storage of notes as well as execution of the various transactions related to central bank digital money.

Therefore, this part of the Technical Guideline on the design of secure CBDC deals with the requirements for IT security aspects of the frontend for the management of digital central bank currencies.

Overall, the digital central bank money, as well as the previously known central bank money, must be fully available. Thus, it is necessary that legally secure transactions can be processed online and possibly also offline.

This Technical Guideline is therefore intended to help developers and providers of wallets for digital central bank currencies to take into account the necessary aspects from the outset according to the principle of security by design, thereby making wallets secure and enabling secure transactions.

Cryptocurrencies not issued and managed by an official body do not fall within the scope of this TR. Furthermore, this TR does not contain an exhaustive treatment of data protection requirements, and compliance with this TR does not necessarily mean compliance with the General Data Protection Regulation (GDPR [2]). Similarly, this TR contains some references to Know Your Customer (KYC) and Anti-Money Laundering (AML) Regulation, but explicit provisions in this sense do not fall within the scope of this TR.

1.3 Overview of the Technical Guideline

This Technical Guideline seamlessly follows TR-03179-1 and has the subject matter to ensure the security framework conditions, especially for use in the context of interactions between participating parties.

Chapter 2 of the Technical Guideline discusses basic high-level security properties. Chapter 3 and 4 explain process/object-oriented security requirements based on threats and specific security objectives.

In essence, requirements for wallets and other hardware, authorisation, storage, synchronisation with the backend, behaviour in the context of updates, but also transaction-specific security requirements will be defined.

1.4 Terms & Explanations

Term	Description
SHALL	This word means that the implementation is an absolute requirement.
SHALL NOT	This phrase means that the implementation is an absolute prohibition.
SHOULD	This word means that the implementation is an absolute requirement unless it is demonstrated that there is no risk to secure operation by not implementing it, or implementation, due to technical limitations, is not currently feasible.
SHOULD NOT	This phrase means that the implementation is an absolute prohibition unless it is demonstrated that there is no risk to secure operation by implementing it, or, due to technical limitations, prevention of the prohibited practice is not currently feasible.
MAY	This word means that the implementation is optional.

Table 1: Modal verbs and their meaning in this document

Term	Description
Objectives	The objectives set out in the relevant chapters are intended to ensure an adequate and sufficient level of security in the use of CBDCs in the respective phase of the life cycle.
Threats	Threats cover all relevant hazards that can lead to significant damage and which are realistic in the present use case and application environment.
Requirements	In principle, the requirements of Technical Guidelines TR-03161-1 and -2 apply to a wallet that is implemented as an app on a mobile device. In addition, the requirements listed in this TR apply. In case of doubt, the requirements listed in this section take precedence. It is necessary to define different requirements that take the specific conditions of CBDC into account. With the CBDC system, the security objectives must be met to a high degree of confidentiality, availability and integrity, because only then can the necessary trust be gained in a new solution.

Table 2: Definition of basic terms and their usage in this document

1.5 Conditions and alliance with other publications

To use CBDC, applications known as ‘apps’ are needed that run on a mobile platform, here primarily on a smartphone. The mobile applications can be divided into native applications that run directly on the smartphone platform and web applications for mobile use. Hybrid solutions that combine both approaches are also conceivable, but not explicitly discussed in this TR.

For the purposes of this Technical Guideline, mobile applications are understood as synonymous with native apps. In this context, web applications can be run on a mobile device, but also on (stationary) personal computers.

For users who do not have access to the above described devices, , this TR also considers the use of smartcards and other hardware form factors as a variant of using CBDC notes.

In addition to the requirements of this Technical Guideline on frontend systems, on the use of CBDC, there are other publications whose requirements for technical solutions should be taken into account during development, as they include basic IT security aspects:

- BSI-TR-02102 Cryptographic measures [3]
- BSI TR-03107 Elektronische Identitäten und Vertrauensdienste im E-Government [4]
- BSI TR-03116 Kryptographische Vorgaben für Projekte der Bundesregierung [5]
- BSI TR-03119 - Requirements for Smart Card Readers Supporting eID and eSign Based on Extended Access Control [6]
- BSI TR-03151 Secure Element API (SE API) [7]
- BSI TR-03161 Anforderungen an Anwendungen im Gesundheitswesen - Teil 1: Mobile Anwendungen [8]
- BSI TR-03161 Anforderungen an Anwendungen im Gesundheitswesen - Teil 2: Web-Anwendungen [9]

- BSI TR-03166 Technical Guideline for Biometric Authentication Components in Devices for Authentication [10].

2 Overview of security requirements

2.1 Life cycle, entities and components

This part of the Technical Guideline represents the life cycle of the wallet and the corresponding components that require the use of the CBDC notes. The use of the wallet begins with the onboarding, in which access to the wallet is established. This includes the download or purchase of the wallet and, depending on the type of wallet, the personal identification of the user. These points are not further considered in this technical guideline.

This Technical Guideline provides information on the following important phases for the life cycle of a wallet:

- Authentication and authorisation
 - User authentication to open the wallet
 - Authorisation of Transactions
- Exchange
 - Loading wallet
 - Receiving CBDC notes
- Storage
 - Secure storage of CBDC notes
 - Denomination of CBDC notes
 - Copy protection, integrity protection and misuse protection
- Update
 - Update of a wallet
 - Update of CBDC notes
- Wallet accounting
 - Transparency about personal transactions and balance
- Transactions Payment
 - Transactions between different wallet software
- Validity check
 - Verification of transactions or notes, which takes place mainly in the CBDC backend system, is an important point in the use of wallets. For more information see TR Backend [1]
- Restrictions on wallet access
 - Reactivation
 - Blocking
 - Locking
- Deletion
 - Exchange of CBDC balances
 - Delete user data
 - Delete the wallet software

2.2 General considerations

2.2.1 Delegation of responsibility

When assigning responsible entities for the requirements laid down in several chapters, this part of the Technical Guideline uses the term ‘the wallet provider’ to clarify that ultimate responsibility for the IT security of the wallets lies with their respective wallet provider. That notwithstanding, in practice it is reasonable to expect that a wallet provider may delegate its responsibilities partly or entirely to other supporting entities. Clear legal and organisational processes will be necessary to guarantee that the supporting entities satisfy all requirements delegated to them by the wallet provider, but such processes are not in the scope of this Technical Guideline.

For some tasks, the responsible entity will be determined by legislation or other decisions from outside the CBDC ecosystem. It is not within the scope of this TR to decide, for example, who is responsible for certifying a wallet provider or for mandating the blocking of a wallet. This TR uses the generic term ‘competent authority’ whenever it refers to such an entity.

2.2.2 Crypto-agility

Regardless of its concrete implementation, the CBDC system will make heavy use of cryptographic protocols and algorithms to ensure the IT security of all processes. In particular, the CBDC notes themselves will involve cryptographic algorithms for protecting their integrity and authenticity, thus preventing use of counterfeit money.

The level of security which specific cryptographic protocols and algorithms can provide against attacks is not static but decreases over time. This is due to the gradual increase in computing power, to algorithmic and technical improvements, and to unexpected security breaches. Overall, this leads to an arms race similar to the one which exists for traditional central bank money (i. e. physical cash). Physical cash contains a certain set of security features, which attackers must replicate to be able to use counterfeit money without being detected. Over time, attackers' skills and equipment evolve, and from time to time existing security features must be modified or new ones added to maintain the desired level of security against counterfeit money.

The same requirement arises for CBDC notes, for which it is necessary to update the cryptographic protocols and algorithms before they lose their security guarantees (cf. TR Backend [1], 3.1.6). A security update can consist in a change of parameters, but also in the replacement of algorithms or protocols by different ones with higher security guarantees. A process must be in place to carry out these updates in an efficient way. Predictions on the exact time when the security guarantee of algorithms will expire are impossible, and the degree of uncertainty of predictions becomes substantial when looking more than a few years ahead, while surprises and rapid deterioration of the security level are in principle always possible. For this reason, following the principle of security by design, an update process must be an integral part of the CBDC system from the start to ensure the CBDC can still be securely used in the future.

2.2.3 Use cases

Although the technical guideline rarely refers to specific use cases and therefore no real differences are made in the requirements, different application possibilities are conceivable.

These use cases differ in payment method or functions of the wallet for the use of CBDCs. Since the forms of P2P payments are different to M2M payments, not every wallet can cover all use cases or functions.

Under P2P payments, the electronic transfer of CBDC between two parties can be subsumed with individual wallets. It may be necessary to distinguish between transactions between individuals and companies (P2B), business to business (B2B) or business to person (B2P).

Payments are also conceivable with the government as a party involved. These wallets can be similar to business transactions. These include X2G (Person or Business-to-Government) or G2X (Government-to-Person or Business).

For transactions, it may be desirable to select the recipient based on an individual identifier, e. g. user name, e-mail address or telephone number. The amount and purpose of a transfer could then be entered or scanned and the transaction must be confirmed.

For some use cases, payments should be executed within a few seconds, similar to SEPA instant payments, and approved immediately and traceably.

The use of CBDCs in the M2M environment is also possible but requires (political) decisions, as machines act for natural or legal persons, but do not have a clear identity. It is necessary to define, within a legal framework, how payments can be clearly attributed to them or how payments can be demanded from them.

Further use cases and functionalities can be developed to keep the design of the digital currency flexible in this official development phase.

2.2.3.1 Transaction features

The following features can be part of the above-mentioned use cases. Although they may be desirable in their respective use cases, they are not necessarily of utmost priority in the fundamental design of retail CBDC. The implementation of these features may not even be practicable in all situations, e. g. offline scenarios, or for all wallet form factors, e. g. smart cards. It may require additional organisational measures, e. g. for organising recurring payments, to implement a CBDC ecosystem that supports all of these features.

Instant Payments

These are payment transactions that are credited immediately after the payment has been made. This feature could be a vital part of most use cases.

Recurring payments

Wallets/applications may need to be able to manage recurring payments, for example, for salary payments or subscriptions. Recurring payments could be important for P2P payments.

Interoperability

Transactions from the bank account to different kinds of wallets and between wallets could also be important, even across national borders. Appropriate fees may then be charged for this. CBDC must be as universally usable as cash. Therefore, it should be compatible with other digital currencies so that financial flows can be executed globally. This feature should be part of every use case.

Refund of a payment / reversal

In principle it is excluded that payments can be withdrawn by the payer. Nevertheless, it could be necessary to use wallets to map processes such as the reversal of transactions (e. g., return of goods in an online transaction). Refunding payments would especially be relevant for P2B payments (cf. 2.2.5.3 'Reversing a transaction').

2.2.4 Wallets

Wallets are a central part of the CBDC infrastructure. They are the place where the CBDC notes are kept safe. They are a physical medium, hardware (device) or software (program, service) used by CBDC users to store the notes. Wallets interact with the backend depending on the layout and are used to track property as well as sending and receiving CBDC notes.

In the context of this TR, it is assumed that wallets are installed and held by natural persons. In the B2X and G2X areas, it may be necessary that several employees have access to the company wallet. However, since the access to the CBDC note is bound to the corresponding hardware, it is not technically possible to issue individual hardware tokens to the employees that all access the same wallet. Further development is necessary, for example, of functions at the meta level that allow binding several wallets to a single company account. However, this aspect is not covered in this TR.

There are different types of wallets for different user requirements, for different use cases and ways of use, see also 2.2.3 'Use cases'.

2.2.4.1 Form factors

The different design of the wallets can be shown in different form factors, so a wallet can be implemented both as an app on a smartphone as well as a web frontend or as hardware solutions such as smart cards or hardware tokens in USB sticks, wearables or key rings. When choosing the form factor, it is important to know that not every form factor can cover every functionality of a wallet.

It is common to hardware wallets that they have a chip integrated, but they are without a permanent internet connection. The chip provides sufficient storage space for the CBDC notes or their respective access credentials and the necessary cryptographic processes. For software wallets, this information is stored in a secure way on the mobile device as described in 3.2 'Hardware and interfaces'.

For the full use of wallets without an internet connection like wallets on smartcards, contact with an acceptance device, such as a smartphone or a card reader, which is approved for payment transactions is necessary. These wallets communicate with each other, for example, with Near Field Communication (NFC). Possible extensions to a hardware wallet would be fingerprint readers that can be used as part of multi-factor authentication, or a screen that displays the current CBDC cash balance. However, these extensions are as optional as additional communication interfaces.

With two mobile devices, it is possible to carry out transactions without a card reader, namely by touching two phones together. The fact that a device does not have an internet connection does not necessarily mean it does not have any capability of direct communication at all.

In order to operate software wallets securely on mobile devices, these devices must have a (embedded) secured hardware anchor. Only through the use of hardware security, in which cryptographic operations are performed using hardware security, functionalities such as offline payments can be activated. Requirements

for the security of general smartphone applications, which could include wallets, can be found e. g. in TR-03161-1 [8].

Different form factors also influence the methods and process flows for the user authentication.

Software wallets will usually run on a device, such as a smartphone or wearable, which itself needs to be unlocked before the user can even start the wallet. The unlock mechanism can be based on diverse authentication means ranging from PIN or password to biometric modalities such as fingerprint or face. Smartcard-based hardware wallets on the other hand will in general require no extra unlocking of the device.

Differences may also concern the time frame for which an authentication remains valid and under which circumstances a re-authentication to unlock the device becomes necessary, e. g. after prolonged idle time or when taking off a wearable.

All this affects the authentication methods and the access to the CBDC wallet, but an exhaustive discussion on all possibilities is out of scope of this TR. Instead, for a unified treatment of the various cases, this TR assumes that the wallet implements a two-step approach in the sense that some authentication means is necessary for starting the wallet and another authentication step is required for confirming each transaction.

3.3 'Authentication and authorisation' will elaborate on the details and on exceptions. For example, in case of a smartcard-based hardware wallet, the first authentication means may simply be the possession of the smartcard, whereas for a smartphone-based software wallet the first authentication factor should be based on PINs, biometrics or similar.

2.2.4.2 Personalised or anonymous wallets

There is not only a distinction between software and hardware wallets. It is also important to distinguish between 'personalised' and 'anonymous' wallets (cf. TR Backend [1]).

Wallet users may have a legitimate interest in executing payments that are not subject to full monitoring. However, completely anonymous CBDCs are contrary to the existing KYC rules and the AML regulation and could be misused for illegal purposes.

The considerations lead to offering (at least) two types of wallets: personalised wallets and completely anonymous or, depending on the design, rather pseudonymous wallets.

Personalised wallets are suitable for full participation in the CBDC system, while 'anonymous' wallets may have a limited functionality.

For anonymous wallets, which could be designed as anonymous prepaid cards, for example, it must be determined whether they need to be registered like prepaid SIM cards, while the buyer is not recorded separately.

In order to provide users with full flexibility, it would be conceivable that 'hybrid' software wallets host different subwallets with different levels of personalisation, allowing for both personalised and pseudonymised transactions.

Definitions and regulations on the part of the legislator are still necessary. For example, it is necessary to determine whether a user may have multiple wallets. If this is possible, it must be determined how many wallets can be held by one person. Limiting the number of wallets could be used to monitor the so-called holding limits in wallets (cf. 2.2.4.3 'Holding limits'). However, any further discussion about the number of wallets a user is allowed to hold and how this limit would be enforced and controlled is out of scope of this TR.

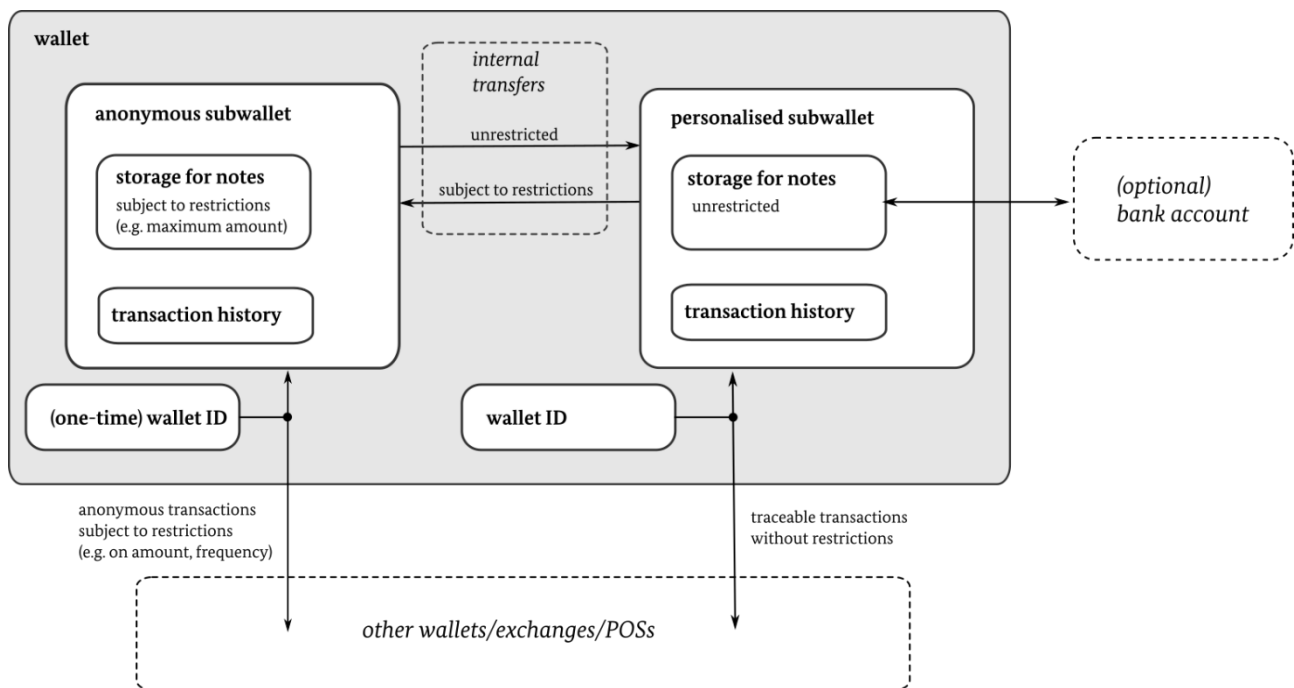


Figure 1: Possible model of a wallet with anonymous and personalised subwallet (cf. 3.4 'Personalisation')

2.2.4.3 Holding limits

Holding limits or a cap on holding CBDC notes are planned to be prepared for disruptions in the banking and financial system in the event of a financial crisis. With a holding limit, CBDC wallets cannot be used as a financial investment product. If customers suddenly want to empty their accounts, the impact to the financial system can be limited.

Nevertheless, even with a fixed ceiling, payments must be simple and efficient. If the limit is reached, the excess balance can be transferred directly to a bank account. Business users in particular must either be able to accumulate stocks of CBDC or be provided with efficient exchange mechanisms in order to be able to make all the required payments. These requirements also apply to public authorities and the public service, so that CBDC can also be used without restriction, regardless of holding limits.

For anonymous wallets that do not have an account in the background, the limit will be lower than for personalised wallets.

In summary, in order to be able to send or receive amounts that are larger than the set holding limits, a fixed connection to a bank account is needed as the money cannot be stored in the CBDC wallet itself. As a consequence, when the transfer to or from an account is not possible, transactions of too high value will not be carried out.

2.2.4.4 Token-based approach versus account-based approach

There are two different approaches to organising CBDC notes in a wallet. The token-based approach treats each CBDC note as an individual token that can be stored or transferred and is as such similar to a classical bank note. On the other hand, in the account-based approach, the wallet only stores the total balance of a user's account but no individual CBDC notes. So as not to give the perception of favouring one approach over the other, this part of the TR will not use the terms 'account' and 'token' and will speak of 'CBDC notes' instead. That means, 'CBDC note' will refer to a piece of data representing a certain amount of CBDC. In particular, in the account-based approach, an account will be treated as one single CBDC note, parts of which may be spent in a transaction and into which all incoming CBDC notes are automatically aggregated (see also TR Backend [1]).

While viewing an account as a CBDC note of its own may be convenient for certain technical aspects, there are still differences between the account-based and the token-based approach that must be considered.

One advantage usually ascribed to the account-based approach is that it is considered to be more easily compatible with AML regulation: For example, if the CBDC note representing a user's total balance has

reached a certain amount, the wallet may refuse to receive any further payments, thus enforcing a limit on the CBDC amount a user is allowed to hold. In a token-based approach, however, there is no explicit information about a user's total balance. Enforcing a limit would therefore require some additional measures on the wallet-side allowing it to keep up with the total amount of CBDC notes it stores.

As seen in 2.2.4.2 'Personalised or anonymous wallets', wallets may come with different degrees of anonymity. CBDC notes, on the other hand, are not supposed to reveal any information about their owner. In the token-based approach, this seeming conflict may easily be resolved, as there is a natural distinction between CBDC notes and the wallet. Implementations that take the account-based approach, however, must take care to preserve a strict separation between the possibly personalised wallet and the account stored on it so as not to leak personal information in the transactions.

While this separation is important to maintain privacy, it poses problems to security: In order to authenticate payments and to avoid double spending, all transactions and the involved CBDC notes will need to pass some background validity check (see TR Backend [1]). In the token-based approach, this validity check can be performed on the individual CBDC notes themselves. In the account-based approach, however, all received CBDC notes are merged into the total balance, so that, without further arrangements, the original CBDC notes can no longer be traced nor preserve a proof of their validity. Instead, in this approach, trust in a transaction's validity is often replaced by trust in the correct authentication of the wallet owner. This, however, is in conflict with the privacy considerations above, which implementations must resolve. In any case, implementations must ensure that merging a CBDC note into the total balance does not discard any information that is necessary to perform the validity check, even if the check has to be postponed until an online connection can be established.

2.2.4.5 Exchange

The meaning of exchange in the context of the Technical Guideline is the change of cash – or other forms of money – against CBDC. The exchange points do not necessarily have to be controlled and operated by the central bank. On the technical level, exchanging CBDC notes against other forms of money consists of a CBDC payment and transaction in the respective form of money. In the case of CBDC notes, it must be clear that the notes are only created by the central bank. Corresponding wallets check the notes and only accept genuine notes issued by the central bank. In return, only genuine notes are converted back into cash or fiat money.

Corresponding checks – the so-called validity check – take place in the CBDC backend system.

2.2.4.6 Onboarding

Onboarding is clearly regulated in the banking sector. If we assume that a wallet is linked to an account, the user is already identified by the bank's account opening. That means, if there is an existing business relationship, the data already collected should be used and not requested again. If there is no existing business relationship, the user has to be onboarded by the wallet provider by an onboarding process and performs know your customer (KYC) checks.

In the case of a wallet that is not linked to an account, for example a wallet that is topped-up by means of a prepaid card, it must be clarified whether an identification must also be carried out in accordance with applicable law.

However, the steps of identification and the further onboarding process are not the subject of this document (see Assumption A.06). Other aspects of the onboarding process, in particular those relating to authentication and authorisation and the provision of appropriate means of authentication, are mentioned in 3.3 'Authentication and authorisation'.

2.2.4.7 Restrictions on access

While using a wallet, it may become necessary to disable the wallet and restrict access to the CBDC notes contained therein. This can be a temporary deactivation of the wallet by the users, if they know that they will not use the wallet for a while. The state can be reversed in a controlled manner with a reactivation of the wallet. Due to the loss of the wallet or unwanted events such as security issues, it may become necessary for the user to lock the wallet remotely. This lock can also be removed at the user's request.

It is also possible to block the wallet, which can only be done by a competent authority such as the central bank.

Note that locking and blocking may not be effectively possible for wallets that are kept offline. General requirements that limit the offline use of a wallet may reduce but not completely solve this problem. (See also the discussion in 3.5 'Disabling and blocking'.)

Deactivation

The user decides not to use the wallet for a longer period of time. In this case, processes or functions that allow temporary, reversible deactivation of the wallet are useful. The goal of deactivation is to reduce any risks during non-use, such as unnoticed access, by, for example, shutting off unnecessary interface functions. Functions that require occasional communication with the backend, for example to receive update information, should not be deactivated.

Another variant is the automatic deactivation of wallets in case of prolonged inactivity. This can be cancelled, for example, by a reactivation PIN or by charging the prepaid wallet.

Reactivation

With the reactivation of the wallet, the deactivation carried out by the user himself is to be reversed in a controlled manner. Before the wallet can be fully reused after reactivation, a phase of updates must be completed. This includes updating the wallet software, as well as the corresponding certificates and connections and the CBDC notes.

Locking

Under certain circumstances, a user must be able to have their wallet locked even if he has lost access to it. In this case, the locking is understood as the non-executability of functions. A locking can be initiated in response to the loss – be it through theft or misplacing – of a wallet, to the forgetting of the credentials or due to unwanted events. A lock can be lifted by the user. As with reactivation, an update of the software and notes etc. would have to be done before reuse.

Blocking

Blocking a wallet may be necessary if the user violates all regulations or if there is a suspicion of manipulation. The blocking can only be executed by a competent authority such as the central bank. It is important to consider how this blockade can be carried out.

For blocking it is necessary to establish processes and control points, which define on the one hand when the execution of blockages is appropriate or even required, but it is also necessary to define under which conditions the blockages can be lifted again so that all functions are available again.

2.2.5 Other technical design choices

This section provides comments and explanations on several crucial aspects of the life cycle, the involved entities and components. In particular, in several places fundamental design choices must be made which have very far-reaching implications. Many of these design choices are general decisions on the trade-off between excessive surveillance and legitimate monitoring functions for AML and KYC purposes in conjunction with measures for mitigating fraud and misconduct. These decisions are extremely sensitive in nature and can strongly influence the level of trust that users place into the CBDC. In addition, they do not directly influence the IT security of the system, although they may have an impact on the ability to manage some fraud scenarios. However, such choices do have strong consequences for the design of the system and must hence be considered from the start. For this reason, the present section describes the respective issues and the trade-offs involved and provides some alternative implementations on the technical level. It does not, however, mandate any design choices. Such choices are entirely left to the competent parties, in particular the legislator who must ensure conformity to existing legislation such as the GDPR [2] and furthermore should make these choices based on the consideration of the legitimate interests of all affected parties and the implications for users' trust in the CBDC.

See also TR Backend [1], 2.2.4.3 and 2.2.4.6, for a more detailed discussion about the challenges and trade-offs that need to be made when introducing functionality for, respectively, the revocation and recovery of CBDC notes.

2.2.5.1 Offline payments

It must be decided to what extent and under what conditions offline payments should be possible. From a security point of view, offline payments do not allow performing a comprehensive validity check as described in the life cycle (cf. TR Backend [1]) and thus face a somewhat higher risk of manipulated payments. This risk can be strongly mitigated by using robust cryptographic protocols and algorithms and

appropriate hardware protection. Offline payments also preclude monitoring for AML purposes. On the other hand, in comparison to traditional payment systems, the possibility for offline payments increases usability and availability of the system by allowing for instant payments, since they only need electricity to work, and still do so in the event of failures of the backend systems or of internet connection issues. Allowing offline payments thus provides a fall-back position in the case of adverse events. A convincing way to benefit from the advantages while mitigating the problems is to allow offline payments, while being subject to certain restrictions (e. g. amount of money, number of payments, amount of time, cf. TR Backend [1], 3.1.8).

2.2.5.2 Update mechanism for CBDC notes

Implementation of update functionalities is an important design choice. Updated CBDC notes must meet the same requirements as the original CBDC notes, in particular, it must be verifiable that they originate from the issuer. There are several possible ways of accomplishing this:

One approach would be that users are asked to exchange their legacy CBDC notes against new ones that have been freshly created by the issuer according to a specification update. Such an exchange could be organised as an ordinary exchange transaction between a user and an exchange point which is securely bound to a second transaction in which the user delivers the legacy CBDC notes to the revocation authority. As the updated CBDC notes follow the same life cycle as all other CBDC notes, they will also satisfy the same requirements. However, a crucial point in this approach is the preservation of privacy. Naively, the user would need to disclose the value of their CBDC notes before being entitled to a replacement of the same value. From a privacy perspective, this is highly undesirable. Implementations taking this approach must therefore implement additional measures to ensure that the update process does not leak any information about the CBDC notes a user wishes to update.

A different approach could put the wallets in charge of the updates. All wallets would be informed about the new specification by the issuer. Afterwards, whenever a wallet detected any legacy CBDC note, it could apply the update with little or no interaction by the user. Note that applying an update to CBDC notes would not a priori involve the issuer nor require an online connection, which could be seen as an advantage. However, in this approach it would be necessary to give the wallets the permission to modify existing CBDC notes. Such a permission poses serious security risks to the CBDC system not only from malicious or buggy implementations of the update process itself but also because it may open a gateway for further attacks. Implementations taking this approach must securely encapsulate the update process and must ensure that all modifications are provably in conformity with the issuer's update specification. It is to be expected that this cannot be achieved without an involvement of the CBDC backend system, which would negate any seeming advantage of offline update capabilities.

2.2.5.3 Reversing a transaction

In some situations, the reversal of a payment is desirable, for example, in case of careless mistakes in the payment details or when a user wishes to withdraw from a transaction. Wherever a right of withdrawal applies, in particular in the P2B context, the provision of a reversal mechanism would not only be desirable but required by law.

In order to keep the transaction history on all involved wallets and the CBDC backend system consistent and not to interfere with any double spending detection measures, a reversal cannot securely be implemented by a naïve deletion of all transaction-related data. Instead, reversal should be implemented by a second transaction in the opposite direction. For this second transaction, the same rules and security measures apply as for any other transaction.

Note that, as with other payment methods, a customer may need to present some sort of receipt to claim refund so that the vendor can be sure that they will send the reverse transaction to the correct person. The transaction details alone provide only insufficient information, in particular, if the customer chose to use an anonymous payment or a one-time wallet ID for the original payment transaction. This aspect, however, needs to be solved by use of a higher-level accounting mechanism and is out of scope of the present document.

2.3 Security problem definition

2.3.1 Organisational Security Policies

An organisational security policy is a set of rules or procedures that is imposed by an organisation on its operations to protect its sensitive data.

IT security essentially pursues three protection goals: Confidentiality, integrity and availability. Since financial data is very sensitive, ensuring these protection goals is particularly important.

The mentioned IT-security objectives are

Confidentiality

Confidentiality is the protection against unauthorised disclosure of information. Confidential data and information may only be accessible to authorised persons in the permitted manner. This means, the loss of confidentiality of financial data can have negative consequences for the victim in both private and professional contexts.

Integrity

Integrity means ensuring the intactness of data and the correct functioning of systems. In the area of financial applications, a breach of integrity could result in payments that are initiated by the legitimate account holder being transferred to an account that is not associated with the intended recipient. Therefore, insecure financial applications can cause great economic harm to individuals and entities.

Availability

Availability means that e. g. applications or IT networks can always be used by users as intended. A breach of availability can cause affected users to be unable to make necessary transactions like payments or exchanges. This can then be the basis for further problems if, for example, the purchase made cannot be paid or an invoice due cannot be settled. Therefore, the way in which users are granted access to time-critical resources must be defined.

2.3.2 Assumptions

The following general assumptions for the secure use of wallets are considered fulfilled, i. e. ensuring their validity does not fall within the scope of this technical directive and the requirements laid down therein.

The list of assumptions is not exhaustive. It may be that further general assumptions arise from the experience of using wallets on mobile devices and other crypto-assets

- A.01** The device which is used for holding a CBDC wallet is neither rooted nor jailbroken.
- A.02** The device which is used for holding a CBDC wallet runs the most recent version of its operating system and has installed all available (security) updates.
- A.03** The device is secured against unauthorised use. This means an adequate PIN or effective biometric functionalities.
- A.04** The wallet app which is installed on a user's device is downloaded from a trustworthy source.
- A.05** The user is in possession of a wallet with a suitable form factor.
- A.06** The initial identification of the user was passed.
- A.07** The user does not use public WIFI-hotspots for transactions of CBDCs.
- A.08** The user's authentication means to access the device are not compromised or known to others.
- A.09** The user logs off correctly after using a wallet app.
- A.10** QR codes, e. g. used as convenient input method for payment data, are correct and secure.

3 Wallet

Requirements for a secure operation of the CBDC backend services can be found in TR Backend [1]. In addition to these general requirements, which provide a secure backbone for the CBDC payment system, there are fundamental requirements for the functionality and security features of CBDC wallets. Here are some examples that show both what a wallet should do and what it can't do. Some of the requirements are specified in the text below.

In the following chapters, the requirements for secure wallets are, aside from general functions (3.1) and hardware and interface requirements (3.2), specified separately according to different use cases. Furthermore, there are requirements mentioned for the interoperability of devices and wallets. Each chapter includes objectives, threats, requirements and a corresponding rationale.

3.1 General functions

This chapter starts by looking at requirements for general functions of wallets.

3.1.1 Objectives

- Gen.Wall.Obj.1 Wallets MAY come in various form factors. Wallets that are not approved SHALL NOT be used in the CBDC infrastructure.
- Gen.Wall.Obj.2 Wallets and, where necessary, suitable acceptance devices, e. g. card readers, SHALL be easily available, accessible and interoperable to allow wide acceptance and usability.
- Gen.Wall.Obj.3 Each wallet SHOULD cover a wide range of use cases. It SHALL provide all transaction types necessary for the covered use cases.
- Gen.Wall.Obj.4 Wallets SHALL be based on secure hardware with secure interfaces.
- Gen.Wall.Obj.5 Wallets SHALL implement measures against unauthorised access and abusive behaviour.
- Gen.Wall.Obj.6 Wallets SHALL regularly synchronise with the CBDC backend system.
- Gen.Wall.Obj.7 Wallets SHALL provide functionality for temporary or permanent deactivation.
- Gen.Wall.Obj.8 Wallets SHALL provide full transparency towards the user about the payments made, wallet account, and updates.
- Gen.Wall.Obj.9 Wallets SHOULD provide full transparency towards the user about terms and conditions, in particular with respect to offline payments and neglected updates.
- Gen.Wall.Obj.10 Wallets MAY offer additional functionality to help in organising payments and recipients.
- Gen.Wall.Obj.11 Wallets MAY allow a reduced authentication level for non-critical security services.
- Gen.Wall.Obj.12 Wallets MAY allow customisation and adaption to poor online connection.
- Gen.Wall.Obj.13 Wallets SHALL NOT circumvent validity checks nor accept invalid CBDC notes.
- Gen.Wall.Obj.14 Wallets SHALL NOT circumvent Know Your Customer (KYC) or other regulations.

3.1.2 Threats

- Gen.Wall.Thr.1 Wallets from untrusted sources may pose security risks.
- Gen.Wall.Thr.2 A user cannot get the wallet up and running due to technical problems, such as missing or incompatible infrastructure or unclear documentation.
- Gen.Wall.Thr.3 The CBDC payment system cannot be used because the supported use cases and the provided functionality do not suit the users' purposes.
- Gen.Wall.Thr.4 Attackers gain access to CBDC notes or sensitive data, for example by intercepting or manipulating the wallet or its communication with the CBDC backend system.
- Gen.Wall.Thr.5 Wallet applications, card readers, the CBDC backend systems or communication channels are not available to their usual extent because of, e. g., technical problems, traffic overload, or attacks. They are, temporarily or indefinitely, unable to perform their tasks within an appropriate time frame.
- Gen.Wall.Thr.6 Devices on which wallets are implemented can be lost, stolen or destroyed.

3.1.3 Requirements

- Gen.Wall.Req.1 Wallets MAY come in various form factors.

- Gen.Wall.Req.2 Before a wallet is allowed to participate in the CBDC infrastructure, it SHALL be approved by a competent authority. The competent authority SHALL verify conformity with this TR. This includes requirements for the wallet itself but also for the wallet provider as laid down in 3.9 'Wallet provider'.
- Gen.Wall.Req.3 There SHALL be wallets that are able to perform the necessary operations to fulfil the use cases.
- Gen.Wall.Req.4 Each wallet SHOULD offer a broad coverage of the use cases listed in 2.2.3 'Use cases'. Each wallet SHALL make transparent which use cases it covers. The functionality of the wallet SHALL be documented and the possibilities of use of the wallet SHALL be transparent to the user.
- Gen.Wall.Req.5 The wallet SHALL be based on hardware that is in conformity with 3.2 'Hardware and interfaces' in order to secure, in particular, the integrity of the CBDC notes it stores. Likewise, all interfaces used by the wallet and card readers, where applicable, SHALL be in conformity with the respective requirements in 3.2 'Hardware and interfaces'.
- Gen.Wall.Req.6 All interfaces SHALL be based on established standards in order to be able to be used by all participants. Examples are the developments from PSD2.
- Gen.Wall.Req.7 Access to the wallet SHALL be protected by appropriate authentication methods in conformity with 3.3 'Authentication and authorisation'.
- Gen.Wall.Req.8 Wallets SHALL regularly synchronise with the CBDC backend system as laid down in 3.6 'Synchronisation with the CBDC backend system'.
- Gen.Wall.Req.9 Wallet providers SHALL ensure that the execution of transactions in their wallet solution is in conformance with 4.1 'Payment', 4.2 'Validity check' and TR Backend [1]. In particular, it SHALL include validity checks in both online and offline situations as laid down in TR Backend [1], 3.2.2.
- Gen.Wall.Req.10 Wallets SHALL provide full transparency towards the user about the payments made, wallet account, and updates in accordance with 3.8 'Wallet Accounting' and 3.7 'Update'.
- Gen.Wall.Req.11 In conformity with 3.5 'Disabling and blocking', there SHALL be a process which allows the user to deactivate or lock the account belonging to his or her wallet, e. g. if it has been lost. Likewise, there SHALL be a process which allows the CBDC backend system in cooperation with the wallet providers to block a wallet if it exhibits malicious activity. These processes SHOULD be available at any time, but they MAY be unavailable in offline scenarios.
- Gen.Wall.Req.12 In order to detect malicious activities, wallets SHALL log critical actions and suspicious behaviour—such as faulty log-in attempts, transaction-specific errors and discontinuations, and failed validity checks—in conformity with 3.3 'Authentication and authorisation' and 4.2 'Validity check'. The information logged SHALL be cryptographically protected against manipulation and SHALL include at least:
- a) date,
 - b) time and
 - c) reason for the disorder or improper behaviour.
- Gen.Wall.Req.13 The wallet SHOULD support typical processes that go beyond a standard payment transaction, e. g. preparing recurring payments.
- Gen.Wall.Req.14 A wallet SHOULD have the ability to implement amount-dependent security mechanisms. Higher amounts SHALL be secured with additional security mechanisms. (See 3.3 'Authentication and authorisation')
- Gen.Wall.Req.15 Functionality that does not necessarily require interaction with the CBDC backend system or with other wallets SHALL be available even if an internet connection cannot be established. Such functionality SHOULD include the display of the wallet's transaction history or account balance. If applicable, it MAY include the scheduling of future transactions.
- Gen.Wall.Req.16 Wallets SHALL comply with relevant regulations, in particular with any limits that a competent authority has defined for the maximum number or value of transactions or, where applicable, for the maximum account balance. Such limits SHOULD be enforced at any time with possible exceptions only temporarily and only in offline scenarios.
- Gen.Wall.Req.17 In addition to Gen.Wall.Req.16, wallets with access to a reliable clock MAY impose tighter limits on the maximum (daily) usage in order to reduce the risk of severe financial damage in case of misuse.
- Gen.Wall.Req.18 The availability of the frontend systems SHALL be tailored to the availability requirements of the CBDC backend system (see TR Backend [1] 3.3.12). In order to meet the

availability requirements, targeted measures SHALL be taken by the providers of wallets and card readers.

Gen.Wall.Req.19 The wallet provider SHALL inform the user about the terms and conditions, the wallet functionality, and the risks involved in the usage of the wallet as laid down in 3.9 'Wallet provider'. If technically possible, the information SHOULD also be available from within the wallet itself.

3.1.4 Rationale

<i>Objective</i>	<i>Covered by</i>	<i>Rationale</i>
Gen.Wall.Obj.1	Gen.Wall.Req.1 Gen.Wall.Req.2	Gen.Wall.Obj.1 allows various form factors, but requires that all wallets shall be approved. This is covered by Gen.Wall.Req.1 and Gen.Wall.Req.2.
Gen.Wall.Obj.2	Gen.Wall.Req.6 Gen.Wall.Req.18	Gen.Wall.Obj.2 requires availability, accessibility and interoperability of wallets. Gen.Wall.Req.18 ensures availability. Gen.Wall.Req.6 ensures interoperability.
Gen.Wall.Obj.3	Gen.Wall.Req.4	Gen.Wall.Obj.3 requires a wide range of use cases. This is covered by Gen.Wall.Req.4.
Gen.Wall.Obj.4	Gen.Wall.Req.5	Gen.Wall.Obj.4 requires IT security of the underlying hardware and interfaces. This is covered by Gen.Wall.Req.5.
Gen.Wall.Obj.5	Gen.Wall.Req.5 Gen.Wall.Req.7 Gen.Wall.Req.11 Gen.Wall.Req.12 Gen.Wall.Req.17	Gen.Wall.Obj.5 requires measures against abusive behaviour. Attacks on the hardware are mitigated by the measures referenced in Gen.Wall.Req.5. In addition, Gen.Wall.Req.7 covers appropriate authentication. Gen.Wall.Req.12 covers the logging of suspicious behaviour and Gen.Wall.Req.11 allows malicious wallets to be blocked. Gen.Wall.Req.17 reduces the financial risk in case of misuse.
Gen.Wall.Obj.6	Gen.Wall.Req.8	Gen.Wall.Obj.6 requires a regular synchronisation with the CBDC backend system. This is directly covered by Gen.Wall.Req.8.
Gen.Wall.Obj.7	Gen.Wall.Req.11	Gen.Wall.Obj.7 requires that wallets can be deactivated or locked under certain circumstances. This is covered by Gen.Wall.Req.11.
Gen.Wall.Obj.8	Gen.Wall.Req.10	Gen.Wall.Obj.8 requires transparency with respect to a user's own transactions and wallet management. This is directly covered by Gen.Wall.Req.10.
Gen.Wall.Obj.9	Gen.Wall.Req.19	Gen.Wall.Obj.9 requires transparency with respect to terms and conditions. This is covered by Gen.Wall.Req.19.
Gen.Wall.Obj.10	Gen.Wall.Req.13	Gen.Wall.Obj.10 allows additional functionality for wallet accounting. This is covered by Gen.Wall.Req.13.
Gen.Wall.Obj.11	Gen.Wall.Req.14	Gen.Wall.Obj.11 concerns the authentication level for non-critical security functions. This is directly covered by Gen.Wall.Req.14.
Gen.Wall.Obj.12	Gen.Wall.Req.15	Gen.Wall.Obj.12 concerns customisation and adaption to poor online connections. This is covered by Gen.Wall.Req.15
Gen.Wall.Obj.13	Gen.Wall.Req.9	Gen.Wall.Obj.13 requires that wallets follow the validity checks. This is directly covered by Gen.Wall.Req.9.
Gen.Wall.Obj.14	Gen.Wall.Req.16	Gen.Wall.Obj.14 requires that wallets comply with relevant regulations. This is covered by Gen.Wall.Req.16.

Table 3: Rationale for the objectives of 3.1 'General functions'

<i>Threat</i>	<i>Covered by</i>	<i>Rationale</i>
Gen.Wall.Thr.1	Gen.Wall.Req.2	Gen.Wall.Thr.1 concerns the risks that arise from wallets from untrusted providers. This is prevented by Gen.Wall.Req.2, which only allows approved wallets.
Gen.Wall.Thr.2	Gen.Wall.Req.6 Gen.Wall.Req.18	Gen.Wall.Thr.2 concerns the risk that users cannot use their wallet due to technical problems. This risk is mitigated by

Threat	Covered by	Rationale
	Gen.Wall.Req.19	Gen.Wall.Req.6 enforcing compliance with established standards for interfaces; by the availability requirements in Gen.Wall.Req.18; and by the provision of technical documentation as required by Gen.Wall.Req.19.
Gen.Wall.Thr.3	Gen.Wall.Req.3 Gen.Wall.Req.4 Gen.Wall.Req.13	Gen.Wall.Thr.3 concerns the threat that the CBDC payment system is not used because of unsuitable functionality. Gen.Wall.Req.3 ensures that for every use case, there is a wallet supporting it. Gen.Wall.Req.4 increases the chance that the user's wallet supports all use cases he or she is interested in. Gen.Wall.Req.13 allows additional wallet functionality that user may find useful.
Gen.Wall.Thr.4	Gen.Wall.Req.5 Gen.Wall.Req.7	Gen.Wall.Thr.4 concerns the risk of attacks on the wallets that result in the loss of CBDC notes or sensitive information. This is prevented by the requirements on secure storage and transfer as referenced in Gen.Wall.Req.5 and by the access restrictions referenced in Gen.Wall.Req.7.
Gen.Wall.Thr.5	Gen.Wall.Req.15 Gen.Wall.Req.18	Gen.Wall.Thr.5 concerns the risk of insufficient availability. By Gen.Wall.Req.18, providers must ensure an appropriate availability of the frontend systems. Gen.Wall.Req.15 increases the availability by allowing an offline execution for certain operations.
Gen.Wall.Thr.6	Gen.Wall.Req.11	Gen.Wall.Thr.6 concerns the loss of a wallet device. This can be countered by locking the wallet as stated by Gen.Wall.Req.11.

Table 4: Rationale for the threats of 3.1 'General functions'

3.2 Hardware and interfaces

In order to be able to use a wallet that manages CBDC securely, requirements must be realised through the hardware and the interfaces.

The hardware on which a wallet runs must include a secure element or a similar security feature to prevent for example double spending in the offline case. More explicitly, the security of the wallet solution must be based on this hardware anchor, while wallets that are based on software alone will not conform with the requirements of this TR.

Since not all smartphones provide a secure area innately, an alternative, i. e. a smart card or different hardware token, must be available to provide the necessary availability as well as a broad user acceptance.

In order for the hardware wallets to participate in the CBDC ecosystem, specific requirements must be implemented for this form factor. These requirements must compensate for the functional limitations in the form that, despite the limitations, secure participation in the CBDC ecosystem is possible.

A problem with most types of form factor is the missing display, so that there is always a need for another acceptance device, e. g. a card reader, equipped with a display and an input device. The acceptance device is required to display the details of the transaction and to ask for confirmation. The regular requirements for secure connections between the smart card and the acceptance device have to be met.

In the area of card-based payment, there are two different types of card readers, which could serve as acceptance device – on the one hand the stationary card readers and then the mobile card readers. This classification can also be transferred to the context of hardware wallets.

A card reader is made up of different components. These include the display, input field, interfaces to the cards, a security module and a module for power supply. An NFC antenna allows contactless reading of the chip in the hardware wallet and also in the smartphone.

A stationary card reader is permanently connected to a POS system and is currently only used with this system. However, it is conceivable that this card reader will also be used to use CBDC wallets to display and ultimately process offline transactions.

A mobile card reader can be used regardless of location and it is generally equipped with an Internet connection to mobile devices. This type of reader is very flexible and is often used in catering, for example.

Overall, it is necessary that when using a card reader or other acceptance device for the communication with the CBDC wallet, transaction details, such as the amount to be paid as well as the recipient data, are displayed directly on the screen of the device. The transaction process is only completed by the user's approval via cryptographic signature, input of a PIN or biometric factors (cf. 4.1 'Payment'), the exact nature of which may depend on the wallet's form factor (cf. 2.2.4.1 'Form factors'). After the confirmation, the acceptance device will forward the data necessary for the transaction to the recipient and also, if an online connection is present, to the CBDC backend system for the online validity check.

The security of acceptance devices in general is out of scope of this Technical Guideline. However, requirements explicitly for card readers are already covered by other technical guidelines of the BSI (see [6]) and also for example in regulations of the German Banking Industry (DK) and the Payment Card Industry Data Security Standard (PCI DSS).

3.2.1 Objectives

- Hard.Wall.Obj.1 The hardware SHALL support effective protection against unauthorised access to the wallet's data and assets.
- Hard.Wall.Obj.2 All interfaces SHALL be secured according to the state of the art.
- Hard.Wall.Obj.3 A copy function for CBDC notes SHALL NOT be provided.
- Hard.Wall.Obj.4 Validity periods and expiry dates for wallets SHALL be established.

3.2.2 Threats

- Hard.Wall.Thr.1 Wallets cannot fulfil the required functionality due to limited interoperability or lack of interface functions.
- Hard.Wall.Thr.2 Unsecured interfaces allow attacks on the wallet, leak sensitive data or can be abused for tricking the user into confirming an unintended transaction.
- Hard.Wall.Thr.3 The hardware on which the wallet runs exhibits a security weakness.

3.2.3 Requirements

- Hard.Wall.Req.1 Only Wallets, that are suitable for handling cryptographic material that corresponds to the state of the art of technology (e. g. TR-02102 [3]) SHALL be used.
- Hard.Wall.Req.2 The wallet (whether it is a smart card or a software wallet) SHALL use hardware-anchored security measures. It SHALL support secure storage of data, in particular of CBDC notes and cryptographic material, for example in a secure element. Access to the storage medium SHALL NOT be possible except through authorised processes.
- Hard.Wall.Req.3 In all wallets, hardware measures SHALL be in place to securely bind cryptographic information about the owner to the CBDC notes it stores (TR Backend [1] 3.2.1).
- Hard.Wall.Req.4 All interfaces SHALL only permit standardised communications. All interfaces not defined for use SHALL be deactivated. Furthermore, defined channels SHALL only be used for the intended purposes.
- Hard.Wall.Req.5 Communication between wallets and the CBDC backend system SHALL be effectively encrypted (cf. TR Backend [1] 3.3.5).
- Hard.Wall.Req.6 Card readers SHALL be approved in conformity with one of the following in the latest version:
 - a) BSI TR-03119 [6],
 - b) PCI PTS (Payment Card Industry PIN Transaction Security, [11]),
 - c) PCI DSS (Payment Card Industry Data Security Standard, [12]).
- Hard.Wall.Req.7 A card reader involved in a transaction SHALL have the technical ability to display transaction details prior to execution. It SHALL also be possible for the user to approve or to abort the transaction.
- Hard.Wall.Req.8 All wallets SHALL have a defined validity period. This holds in particular for smart cards and other self-contained hardware wallets.
- Hard.Wall.Req.9 Wallet providers SHALL ensure that their wallet solution is able to react in a timely manner to security weaknesses in the hardware or operating system (cf. Upd.Wall.Obj.2). For example, wallets SHALL ask for other authentication means if weaknesses in biometric

components become known, or SHALL disable offline transactions if problems with the hardware anchor arise.

3.2.4 Rationale

<i>Objective</i>	<i>Covered by</i>	<i>Rationale</i>
Hard.Wall.Obj.1	Hard.Wall.Req.1 Hard.Wall.Req.2 Hard.Wall.Req.3 Hard.Wall.Req.6	Hard.Wall.Obj.1 requires that the hardware supports the protection against unauthorised access. Hard.Wall.Req.1 and Hard.Wall.Req.2 ensure the secure handling of the relevant cryptographic material in general. Hard.Wall.Req.3 ensures that the wallet hardware restricts access to the CBDC notes to their rightful owner. Hard.Wall.Req.6 makes sure that unauthorised access cannot be gained via untrustworthy card readers or their interfaces.
Hard.Wall.Obj.2	Hard.Wall.Req.4 Hard.Wall.Req.5 Hard.Wall.Req.6	Hard.Wall.Obj.2 requires secure interfaces. This is covered by Hard.Wall.Req.4 and Hard.Wall.Req.6 and, where communication with the CBDC backend system is concerned, by Hard.Wall.Req.5.
Hard.Wall.Obj.3	Hard.Wall.Req.2	Hard.Wall.Obj.3 prohibits that CBDC notes are copied. This is implicitly covered by Hard.Wall.Req.2, which prohibits access to the stored CBDC notes.
Hard.Wall.Obj.4	Hard.Wall.Req.8	Hard.Wall.Obj.4 requires expiry dates for wallets. This is covered by Hard.Wall.Req.8.

Table 5: Rationale for the objectives of 3.2 ‘Hardware’

<i>Threat</i>	<i>Covered by</i>	<i>Rationale</i>
Hard.Wall.Thr.1	Hard.Wall.Req.4 Hard.Wall.Req.6 Hard.Wall.Req.7	Hard.Wall.Thr.1 considers missing interoperability or functionality. A lack of interoperability is prevented by Hard.Wall.Req.4 and Hard.Wall.Req.6 requiring the use of standardised interfaces and card readers, if applicable. Hard.Wall.Req.7 prevents that certain functionality cannot be used on a smartcard wallet due to missing display or input devices.
Hard.Wall.Thr.2	Hard.Wall.Req.4 Hard.Wall.Req.5 Hard.Wall.Req.6	Hard.Wall.Thr.2 considers threats caused by unsecured interfaces. These are prevented by the requirements in Hard.Wall.Req.4 and Hard.Wall.Req.6 and, where communication with the CBDC backend system is concerned, by Hard.Wall.Req.5.
Hard.Wall.Thr.3	Hard.Wall.Req.9	Hard.Wall.Thr.3 considers the threat that the hardware exhibits security weaknesses. A prompt reaction of the wallet provider to avoid that the weakness is exploited through the wallet application is addressed in Hard.Wall.Req.9

Table 6: Rationale for the threats of 3.2 ‘Hardware’

3.3 Authentication and authorisation

This chapter deals with authentication and authorization after the identification has already taken place. Different authentication steps with different authentication factors are necessary for the different actions related to the wallets. Even the user authentication to open the wallet must be mandatory, where technically possible, since the wallet itself contains sensitive data such as the account balance.

An additional authentication step with a different authentication factor should be required to confirm transactions. An exemption from this requirement is possible, if the hardware does not support different authentication factors, for example, for hardware wallets on prepaid cards.

Once authentication and authorization have been carried out successfully, the wallet will access the cryptographic material in the Secure Element or its equivalent in order to prove ownership of the CBDC notes to be transferred (cf. TR Backend [1]).

When contacting the CBDC backend system or other devices, the wallet must be authenticated so that a secure communication channel can be established.

All authentication means – be they PINs or biometrics, the cryptographic material used for the proof of ownership, or the wallet's authentication keys for secure communication – must be handled on an appropriate security level. This applies in particular to a secure creation, storage and destruction of authentication means and includes the possibility of changing or recovering user passwords etc., at least for personalised wallets. Note however that the cryptographic material in the proof of ownership of CBDC notes will not be recoverable if access to the secure element has been irrevocably lost (see the discussion in TR Backend [1] 3.1.7).

3.3.1 Objectives

- Auth.Wall.Obj.1 Before the first use of the wallet, the user SHALL go through an initial onboarding process.
- Auth.Wall.Obj.2 Only authorised persons SHALL have access to their own sensitive data.
- Auth.Wall.Obj.3 Only authorised persons SHALL be able to transfer CBDC notes.
- Auth.Wall.Obj.4 Depending on the type of action performed, the strength of authentication SHALL be selected.
- Auth.Wall.Obj.5 Personalised wallets SHALL support the secure changing, deactivation and recovery of the user's authentication means. After a recovery and successful re-authentication, it SHALL be possible to access the wallet again even if the secret is not accessible.
- Auth.Wall.Obj.6 Failed login attempts to the wallet SHALL be logged.

3.3.2 Threats

- Auth.Wall.Thr.1 An unauthorised person has access to sensitive data.
- Auth.Wall.Thr.2 An unauthorised person has control over a wallet.
- Auth.Wall.Thr.3 An unauthorised person has control over the device on which the wallet is located.
- Auth.Wall.Thr.4 An attacker assumes a role or performs an action for which he is not authorised. In particular, the attacker may take over any communication on behalf of the entity he impersonates.
- Auth.Wall.Thr.5 If the user of the wallet loses the authentication means, he may permanently lose access to the wallet or the CBDC notes.
- Auth.Wall.Thr.6 Authentication procedures conflict with accessibility and reduce user acceptance.

3.3.3 Requirements

- Auth.Wall.Req.1 Before using the wallet for the first time, the user SHALL be in possession of all the necessary authentication means and cryptographic material for the secure use of the wallet and its secure communication with the CBDC backend system. A corresponding onboarding process SHALL be established.
- Auth.Wall.Req.2 Access to the wallet SHALL require user authentication. For smartcard-based hardware wallets, possession of the smartcard MAY count as authentication factor. For all other wallets, in particular software wallets, some other authentication means SHALL be required, i. e. possession of the device on which the wallet runs is not sufficient.
- Auth.Wall.Req.3 Access to a wallet SHALL conform with relevant regulation, such as PSD2, and SHALL be protected in a secure way by appropriate technology mechanisms for the type of wallet. In order to ensure accessibility and user acceptance, various authentication methods SHOULD be offered to the user.
- Auth.Wall.Req.4 The access to the wallet and the authentication of tasks that the wallet performs MAY be based on different levels of assurance. The decision on the appropriate level of assurance and the appropriate authentication procedures SHOULD be based on a risk-oriented approach.
- Auth.Wall.Req.5 Authentication measures, and in particular the generation, protection, management and destruction of authentication means, SHALL follow the state of the art and SHALL comply with the requirements for the respective level of assurance.

- Auth.Wall.Req.6 Authentication means SHALL be securely stored. In particular, the storage of the cryptographic material used for the proof of ownership of the CBDC notes SHALL comply with the requirements in 3.2 'Hardware and interfaces'.
- Auth.Wall.Req.7 The wallet owner SHALL be able to restrict unauthorised access to the wallet by locking it (see 3.5 'Disabling and blocking').
- Auth.Wall.Req.8 Changing the authentication means that are used for accessing the wallet, e. g. user passwords, SHALL require a successful authentication of the user. The wallet SHOULD log date and time of each change of the authentication means.
- Auth.Wall.Req.9 For security reasons, an automatic logout from the (software) wallet SHALL take place after a defined idle time, which SHOULD NOT exceed five minutes. After auto-logout, re-authentication SHALL be required for further use.
- Auth.Wall.Req.10 In addition to the authentication for accessing the wallet (Auth.Wall.Req.2), authentication with a second factor SHALL be in place for confirming transactions (see also 4.1 'Payment'). Relevant regulation SHALL be taken into account.
- Auth.Wall.Req.11 For personalised wallets, wallet providers SHALL implement a secure way to re-establish access to a wallet in case of lost authentication means. For this, there SHALL be a special re-authentication procedure.
- Auth.Wall.Req.12 The wallet SHALL log all failed login attempts and SHOULD inform the user.

3.3.4 Rationale

Objective	Covered by	Rationale
Auth.Wall.Obj.1	Auth.Wall.Req.1	Auth.Wall.Obj.1 requires an initial onboarding process. This is covered by Auth.Wall.Req.1.
Auth.Wall.Obj.2	Auth.Wall.Req.2 Auth.Wall.Req.3 Auth.Wall.Req.8 Auth.Wall.Req.9	Auth.Wall.Obj.2 requires that only the owner can access sensitive data. This is covered by Auth.Wall.Req.2, Auth.Wall.Req.3, Auth.Wall.Req.8 and Auth.Wall.Req.9, which ensure that access to the wallet itself is based on a secure authentication process.
Auth.Wall.Obj.3	Auth.Wall.Req.2 Auth.Wall.Req.3 Auth.Wall.Req.10	Auth.Wall.Obj.3 requires that only the owner can transfer CBDC notes. This is covered by Fehler! Verweisquelle konnte nicht gefunden werden. and Auth.Wall.Req.10, which ensure that only the owner has access to the wallet and to the transactions.
Auth.Wall.Obj.4	Auth.Wall.Req.4	Auth.Wall.Obj.4 allows that the strength of the authentication measures vary with the respective task they protect. This is covered by Auth.Wall.Req.4.
Auth.Wall.Obj.5	Auth.Wall.Req.5 Auth.Wall.Req.8 Auth.Wall.Req.11	Auth.Wall.Obj.5 requires that authentication means for personalised wallets can be changed, deactivated and recovered. General management mechanisms for authentication means are covered by Auth.Wall.Req.5. Auth.Wall.Req.8 treats the changing of authentication means and Auth.Wall.Req.11 the recovery.
Auth.Wall.Obj.6	Auth.Wall.Req.12	Auth.Wall.Obj.6 requires the logging of failed login attempts. This is directly covered by Auth.Wall.Req.12.

Table 7: Rationale for the objectives of 3.3 'Authentication and authorisation'

Threat	Covered by	Rationale
Auth.Wall.Thr.1	Auth.Wall.Req.2 Auth.Wall.Req.3 Auth.Wall.Req.8 Auth.Wall.Req.9	Auth.Wall.Thr.1 concerns the threat of unauthorised access to sensitive data. This is prevented by Auth.Wall.Req.2, Auth.Wall.Req.3, Auth.Wall.Req.8 and Auth.Wall.Req.9, which ensure that access to the wallet itself is based on a secure authentication process.
Auth.Wall.Thr.2	Auth.Wall.Req.2 Auth.Wall.Req.3 Auth.Wall.Req.8 Auth.Wall.Req.9	Auth.Wall.Thr.2 concerns the threat of unauthorised control over the wallet. This is prevented by Auth.Wall.Req.2, Auth.Wall.Req.3, Auth.Wall.Req.8, Auth.Wall.Req.9 and Auth.Wall.Req.10, which ensure that access to the wallet and the

<i>Threat</i>	<i>Covered by</i>	<i>Rationale</i>
	Auth.Wall.Req.10	confirmation of transactions are based on a secure authentication process.
Auth.Wall.Thr.3	Auth.Wall.Req.7	Auth.Wall.Thr.3 concerns the threat of unauthorised control over the wallet device. While loss or theft of a device cannot be prevented, Auth.Wall.Req.7 ensures that the user can mitigate the ensuing risks to the wallet. Assumption A.01 contributes as well.
Auth.Wall.Thr.4	Auth.Wall.Req.2 Auth.Wall.Req.3 Auth.Wall.Req.5 Auth.Wall.Req.6 Auth.Wall.Req.8 Auth.Wall.Req.9 Auth.Wall.Req.10	Auth.Wall.Thr.4 concerns the threat of unauthorised actions or communication. This is prevented by secure authentication as required by Auth.Wall.Req.2, Auth.Wall.Req.3, Auth.Wall.Req.8, Auth.Wall.Req.9 and Auth.Wall.Req.10, and by secure management and storage of authentication means as required by Auth.Wall.Req.5 and Auth.Wall.Req.6.
Auth.Wall.Thr.5	Auth.Wall.Req.6 Auth.Wall.Req.11	Auth.Wall.Thr.5 concerns the risk of losing access to the wallet or the CBDC notes. Auth.Wall.Req.11 ensures that access to the wallet can usually be re-established. Auth.Wall.Req.6 ensures secure storage of internal authentication keys, in particular those used for the proof of ownership of CBDC notes.
Auth.Wall.Thr.6	Auth.Wall.Req.4 Auth.Wall.Req.3	Auth.Wall.Thr.6 concerns the threat that authentication measures reduce the accessibility and acceptance of a wallet. This is mitigated by Auth.Wall.Req.3 which allows various forms of authentication means. Moreover, Auth.Wall.Req.4 allows that uncritical tasks may use a reduced strength of authentication.

Table 8: Rationale for the threats of 3.3 ‘Authentication and authorisation’

3.4 Personalisation

Following the discussion in 2.2.4.2 ‘Personalised or anonymous wallets’, the CBDC payment system may be designed to provide different types of wallets: personalised or anonymous.

To cover all types of wallets simultaneously, this section considers the case of a ‘hybrid’ wallet that can host several distinct subwallets at once (cf. Figure 1). From this perspective, a fully anonymous wallet would be the special case of a hybrid wallet hosting only one (or more) anonymous subwallet(s), whereas a personalised wallet would be a hybrid wallet with only personalised subwallets.

It is further assumed that any personal data that is needed for the use of the personalised subwallets has already been collected and stored as part of the initial onboarding process (cf. 2.3.2 ‘Assumptions’). In this context, it is important that anonymous subwallets must not access this data in order not to be able to share it in a transaction. If wallet owners later wish to make a change to their personal data, they must undergo a process analogous to the onboarding process to ensure that the conformity with KYC regulations remains valid. Like the initial onboarding, this change process is out of scope of this TR.

The technical implementation must be clearly documented and all subwallets must have a unique identifier to be able to participate in a transaction. In the case of completely anonymous subwallets, this could be an ephemeral ID which changes for each transaction.

3.4.1 Objectives

Pers.Wall.Obj.1 A wallet MAY host more than one subwallet. Each subwallet SHALL be either personalised or anonymous.

Pers.Wall.Obj.2 The functionality of subwallets MAY be restricted, for example regarding the holding limit or the maximum value of a transaction.

Pers.Wall.Obj.3 Anonymous subwallets SHALL neither require nor leak personal information.

3.4.2 Threats

Pers.Wall.Thr.1 Restrictions such as holding limits are circumvented by shifting CBDC notes between different subwallets.

Pers.Wall.Thr.2 Anonymous subwallets leak personal information, in particular, because they can access personal data in a personalised subwallet hosted by the same wallet.

3.4.3 Requirements

Pers.Wall Req.1 A wallet SHALL provide at least one subwallet. A subwallet SHALL be either personalised or anonymous. A wallet MAY contain personalised as well as anonymous subwallets.

Pers.Wall Req.2 The functionality of subwallets MAY be restricted in terms of, e. g., the maximum value they can hold or the maximum number of transactions they can initiate or the maximum value that can be transferred in a single transaction. The restrictions MAY depend on whether the subwallet is personalised or anonymous.

Pers.Wall Req.3 Transferring CBDC notes from one subwallet to another SHALL NOT be possible except by means of a payment transaction. This SHALL hold in particular in the case that several subwallets are hosted on the same wallet.

Pers.Wall Req.4 Anonymous subwallets and their respective processes SHALL NOT use or have access to any personal data, in particular the user's name, that is stored on or used by the wallet.

Pers.Wall Req.5 Each time a wallet ID is needed, e. g. as recipient's ID, an anonymous subwallet SHOULD generate a new random one-time ID.

3.4.4 Rationale

Objective	Covered by	Rationale
Pers.Wall.Obj.1	Pers.Wall Req.1	Pers.Wall.Obj.1 concerns the existence and number of subwallets hosted by a single wallet. This is directly covered by Pers.Wall Req.1.
Pers.Wall.Obj.2	Pers.Wall Req.2	Pers.Wall.Obj.2 concerns possible restrictions on the subwallet functionality. This is covered by Pers.Wall Req.2.
Pers.Wall.Obj.3	Pers.Wall Req.4 Pers.Wall Req.5	Pers.Wall.Obj.3 requires that anonymous subwallets do not use or leak personal data. This is addressed by Pers.Wall Req.4 strictly forbidding any access to personal data. Moreover, using a new ID for each transaction, as required by Pers.Wall Req.5, mitigates the risk of users being identified by tracing their subwallet over several transactions.

Table 9: Rationale for the objectives of 3.4 'Personalisation'

Threat	Covered by	Rationale
Pers.Wall.Thr.1	Pers.Wall Req.3	Pers.Wall.Thr.1 considers the threat that restrictions on the wallet functionality may be circumvented by taking advantage of different subwallets or subwallet types. This is mitigated by Pers.Wall Req.3, which prevents that money transfers between subwallets go unnoticed.
Pers.Wall.Thr.2	Pers.Wall Req.4	Pers.Wall.Thr.2 considers the threat that anonymous subwallets leak personal data. This is prevented by Pers.Wall Req.4 denying the anonymous subwallets any access to personal data.

Table 10: Rationale for the threats of 3.4 'Personalisation'

3.5 Disabling and blocking

As discussed in 2.2.4.7 'Restrictions on access', some situations require that a wallet can be temporarily disabled. This may be necessary to proactively prevent unauthorised access to the wallet, or in reaction to malicious behaviour of the wallet itself in order to avert harm to the CBDC payment system.

This section discusses the responsible entities and the preconditions that must be satisfied before a wallet can be disabled. It is clear that both responsibilities and preconditions depend on the type of disabling. For example, a temporary user-initiated deactivation should not require much effort on the side of the user. In

contrast, since the blocking of wallets through a third party, i. e. the central bank, could be a target for attackers and could undermine the users' trust in the CBDC payment system, it is necessary to inflict strict and transparent restrictions on this process.

Preventively locking a wallet to which the owner has lost access, e. g. in case of theft, conflicts with the wish for anonymous payments because the receiving wallet cannot discern whether or not the sender of an anonymous payment is locked. Likewise, in an offline scenario, the receiving wallet may not have sufficient information to decide whether the sender—even if its identity is known—is currently locked. As a consequence, locking a stolen wallet, in particular an anonymous hardware wallet, may not be effectively possible in all cases. Holding limits may therefore play an important role to minimise the financial risk for the user. If the CBDC design allows that a wallet is linked to a user's bank account—so that payments can be executed that exceed the holding limit—then this link must be disabled when a wallet is locked in order to prevent an attacker from using a stolen wallet to gain access to the funds on the user's bank account. The entity that is responsible for locking a wallet may depend on the CBDC design.

Finally, users may also want to permanently delete a wallet from their device. This project requires further considerations, such as the exchange of CBDC balances, the deletion of user data and then the deletion of the wallet software.

3.5.1 Objectives

- Dis.Wall.Obj.1 Users SHOULD be able to temporarily deactivate their wallets. Deactivation MAY also take place at times of prolonged inactivity.
- Dis.Wall.Obj.2 It SHOULD be possible to lock a wallet on request of its owner, even if the owner has no longer access to it, e. g. in case of loss or theft.
- Dis.Wall.Obj.3 It SHOULD be possible to block malicious wallets from participating in the CBDC payment system.
- Dis.Wall.Obj.4 Users SHALL be able to reactivate their wallets after deactivation.
- Dis.Wall.Obj.5 Unlocking a wallet SHOULD be possible on request of the wallet owner.
- Dis.Wall.Obj.6 Unlocking a wallet SHALL NOT be possible except with the permission and cooperation of the confirmation authority.
- Dis.Wall.Obj.7 Users SHALL be able to securely and irrevocably delete an empty software wallet from their device.

3.5.2 Threats

- Dis.Wall.Thr.1 Abuse of a possibly stolen wallet cannot be prevented or stopped.
- Dis.Wall.Thr.2 Abuse of the CBDC payment system cannot be prevented or stopped.
- Dis.Wall.Thr.3 Users are unable to reactivate or unlock their wallet.
- Dis.Wall.Thr.4 Malicious users are able to lift or circumvent the deactivation, locking or blocking of a wallet.
- Dis.Wall.Thr.5 While being disabled, wallets are not provided with important updates.

3.5.3 Requirements

- Dis.Wall.Req.1 Software wallets SHALL provide functionality that allows the deactivation and reactivation of wallets or of individual subwallets. A wallet with access to a reliable clock SHOULD automatically be deactivated if it has not been used for a certain period of time. It SHALL also be possible for the user to initiate the deactivation.
- Dis.Wall.Req.2 Hardware wallets with access to a reliable clock MAY automatically be deactivated in times of prolonged inactivity.
- Dis.Wall.Req.3 If the wallet supports deactivation, it SHALL be possible for a user to reactivate their previously deactivated wallet or subwallet. Reactivation SHALL require authentication of the user. For this, the user SHALL have been provided with dedicated authentication means, e. g. a reactivation PIN (see Auth.Wall.Req.1).
- Dis.Wall.Req.4 While a wallet or subwallet is deactivated, it SHALL NOT be possible to initiate new transactions from the wallet.
- Dis.Wall.Req.5 In the case of user-initiated deactivation, it MAY be possible to deactivate the synchronisation with the CBDC backend system (cf. 3.6 'Synchronisation with the CBDC

- backend system'). However, in case of automatic deactivation during times of inactivity, synchronisation with the CBDC backend system **SHOULD** remain active to the usual extent.
- Dis.Wall.Req.6 Personalised wallets **SHOULD** provide functionality that allows locking and unlocking the wallet on the owner's request. While locking the wallet **SHALL NOT** require that the owner has physical access to the wallet, unlocking **SHALL** only be possible with physical access.
- Dis.Wall.Req.7 Locking and unlocking **SHALL** require authentication of the user at the entity that is responsible for the locking over an out-of-band communication channel. For this, dedicated authentication means **SHALL** be provided to the user (see Auth.Wall.Req.1).
- Dis.Wall.Req.8 While the wallet is locked, it **SHALL NOT** be possible to initiate new transactions from any account hosted on this wallet. A locked wallet **SHALL NOT** synchronise with the CBDC backend system. If the wallet is linked to a user's bank account, this link **SHALL** be disabled.
- Dis.Wall.Req.9 The central bank or, where applicable, another authorised competent authority **SHALL** have the possibility to block a wallet if it has justified reason to believe that this wallet disregard relevant regulation or poses a threat to significant parts of the CBDC payment system. The wallet providers **SHALL** support the central bank in enforcing the blocking (see Prov.Wall.Req.12).
- Dis.Wall.Req.10 While the wallet is blocked, it **SHALL NOT** be able to execute any transactions from any account hosted on this wallet. A blocked wallet **SHALL NOT** synchronise with the CBDC backend system.
- Dis.Wall.Req.11 Unblocking a blocked wallet **SHALL NOT** be possible except through the central bank.
- Dis.Wall.Req.12 After reactivation, unlocking or unblocking, the wallet **SHALL** check whether a synchronisation with the CBDC backend system is due and, if so, **SHALL** perform is before the next transaction is executed.
- Dis.Wall.Req.13 Software wallets **SHALL** provide functionality for secure deletion of the entire wallet from the corresponding device.
- Dis.Wall.Req.14 Deletion **SHALL NOT** be possible if any of the accounts hosted on the wallet contains valid CBDC notes. Deletion of a wallet **SHALL** require authentication of the user and an additional confirmation. Before confirmation, the user **SHALL** be informed that this step is irrevocable.
- Dis.Wall.Req.15 If a wallet is deleted, the app and any locally stored data (cf. 3.8 'Wallet Accounting') **SHALL** be removed from the device. If the wallet is linked to a user's bank account, this link **SHALL** also be deleted.

3.5.4 Rationale

<i>Objective</i>	<i>Covered by</i>	<i>Rationale</i>
Dis.Wall.Obj.1	Dis.Wall.Req.1 Dis.Wall.Req.2	Dis.Wall.Obj.1 concerns functionality for a temporary deactivation. For software wallets, this is a mandatory requirement addressed by Dis.Wall.Req.1. For hardware wallets, automatic deactivation is an optional requirement addressed by Dis.Wall.Req.2.
Dis.Wall.Obj.2	Dis.Wall.Req.6	Dis.Wall.Obj.2 concerns functionality for locking a wallet without having access to it. This is covered by Dis.Wall.Req.6.
Dis.Wall.Obj.3	Dis.Wall.Req.9	Dis.Wall.Obj.3 requires that malicious wallets can be blocked from the CBDC payment system. This is covered by Dis.Wall.Req.9
Dis.Wall.Obj.4	Dis.Wall.Req.3	Dis.Wall.Obj.4 requires that deactivated wallets can be reactivated by their owners. This is directly covered by Dis.Wall.Req.3.
Dis.Wall.Obj.5	Dis.Wall.Req.6	Dis.Wall.Obj.5 requires that it should be possible to unlock a wallet. This is covered by Dis.Wall.Req.6.
Dis.Wall.Obj.6	Dis.Wall.Req.11	Dis.Wall.Obj.6 requires that an unblocking is only possible through the confirmation authority. This is directly covered by Dis.Wall.Req.11.
Dis.Wall.Obj.7	Dis.Wall.Req.13 Dis.Wall.Req.14 Dis.Wall.Req.15	Dis.Wall.Obj.7 requires the possibility to delete a software wallet. This is covered by Dis.Wall.Req.13, Dis.Wall.Req.14 and Dis.Wall.Req.15.

Table 11: Rationale for the objectives of 3.5 'Disabling and blocking'

<i>Threat</i>	<i>Covered by</i>	<i>Rationale</i>
Dis.Wall.Thr.1	Dis.Wall.Req.1 Dis.Wall.Req.2 Dis.Wall.Req.4 Dis.Wall.Req.6 Dis.Wall.Req.8	Dis.Wall.Thr.1 concerns the threat that wallet abuse cannot be prevented or stopped. Dis.Wall.Req.1, Dis.Wall.Req.2 and Dis.Wall.Req.4 allow deactivation as preventive protection measure. Dis.Wall.Req.6 and Dis.Wall.Req.8 allow locking as preventive protection measure.
Dis.Wall.Thr.2	Dis.Wall.Req.9	Dis.Wall.Thr.2 concerns the threat that abuse of the CBDC payment system cannot be prevented or stopped. Dis.Wall.Req.9 allows blocking malicious wallets.
Dis.Wall.Thr.3	Dis.Wall.Req.3 Dis.Wall.Req.7	Dis.Wall.Thr.3 concerns the threat that deactivated or locked wallets cannot be reactivated or unlocked. This is prevented by providing the relevant authentication means, as described in Dis.Wall.Req.3 and Dis.Wall.Req.7.
Dis.Wall.Thr.4	Dis.Wall.Req.3 Dis.Wall.Req.7 Dis.Wall.Req.11	Dis.Wall.Thr.4 concerns the threat that disabling mechanisms can be circumvented. In the case of deactivation or locking, Dis.Wall.Req.3 and Dis.Wall.Req.7 ensures that no unauthorised reactivation or unlocking can take place. Dis.Wall.Req.11 ensures that only the central bank can unblock a wallet.
Dis.Wall.Thr.5	Dis.Wall.Req.5 Dis.Wall.Req.12	Dis.Wall.Thr.5 concerns the threat that disabled wallets are not kept up to date. This is mitigated by Dis.Wall.Req.5 requiring that wallets shall synchronise with the CBDC backend whenever possible, even when they are deactivated. Dis.Wall.Req.12 ensures that missed updates are applied as soon as possible.

Table 12: Rationale for the threats of 3.5 ‚Disabling and blocking‘

3.6 Synchronisation with the CBDC backend system

To ensure a secure and uninterrupted provision of offline functionality, it is necessary that, during times when an online connection can be established, the wallet synchronise relevant data with the CBDC backend system. Since the synchronisation process must not in itself pose a security threat, the authenticity and integrity of the exchange data must be verified.

Data that the wallet receives from the CBDC backend system includes cryptographic key material of the central bank and information about currently supported CBDC versions (cf. TR Backend [1], 3.1.6, 3.2.2 and 3.3.4). Neither key material nor CBDC versions are expected to change very often. However, a security incident may render an immediate exchange necessary. Wallets must pursue regular synchronisations to keep up with such changes. Depending on the changes that a particular update entails, it may also become necessary to update the wallet hardware before these changes can be applied. However, updating the wallet hardware is out of scope of this TR.

Conversely, the wallet must submit failure reports which the CBDC backend system needs in order to detect suspicious behaviour. From a security perspective, a frequent reporting would be desirable. Also, wallets with limited memory capacity that may not be able to buffer large amounts of data would benefit from a high synchronisation frequency. However, it must be taken into account that synchronisation may slow down the wallet’s operation and may, in the worst case, have negative effects on usability and user acceptance.

The requirements in this section leave room to a certain degree of flexibility, so that wallets may adjust the synchronisation frequency to hardware constraints, the size of buffered transaction data, connectivity conditions or similar.

3.6.1 Objectives

Sync.Wall.Obj.1 The wallet SHALL regularly receive from the CBDC backend updates of all locally stored information that is needed for offline validity checks. The updated information SHALL be stored and its integrity and authenticity SHALL be protected.

Sync.Wall.Obj.2 The wallet SHALL regularly inform the CBDC backend about any suspicious behaviour it has detected.

Sync.Wall.Obj.3 The default synchronisation frequency SHALL find a reasonable balance between, on the one hand, the timeliness and accuracy of information and, on the other hand, negative effects on the wallet performance. In case of urgent security-related reports, out-of-turn synchronisations SHOULD take place.

Sync.Wall.Obj.4 The necessity of regular synchronisations with the CBDC backend system and the consequences of non-compliance SHALL be made transparent to the user.

3.6.2 Threats

Sync.Wall.Thr.1 Offline validity checks lead to incorrect results because some relevant information stored locally in the wallet is outdated or missing.

Sync.Wall.Thr.2 A wallet cannot perform further offline transactions because it has reached the limit defined by TR Backend [1].

Sync.Wall.Thr.3 Security relevant information that is collected by the wallets is not evaluated by the CBDC backend system in a timely manner.

Sync.Wall.Thr.4 Synchronisation has a severe negative effect on the performance of the wallet, in particular of the transaction functionality.

Sync.Wall.Thr.5 An attacker uses the synchronisation process to inject malicious data or malware into user wallets.

3.6.3 Requirements

Sync.Wall.Req.1 When the wallet establishes an online connection to the CBDC backend system, it SHALL check whether a synchronisation of relevant data is necessary. This SHALL at least be the case if the time interval since the last synchronisation has exceeded a certain limit, which is to be defined by the central bank and SHOULD not be more than 1 week, or if the CBDC backend system calls for an immediate synchronisation, e. g. in case of a security incident (cf. TR Backend [1] EM.Req.8).

Sync.Wall.Req.2 For wallets that are designed for use cases in which a high transaction frequency is expected, the pre-defined time interval between synchronisation processes (cf. Sync.Wall.Req.1) SHOULD not exceed 1 day.

Sync.Wall.Req.3 During synchronisation, the wallet SHALL ensure that the locally stored key material referenced in TR Backend [1] (3.2.2) and TR Backend [1] (Table 36) is up to date with the issuer's current key material provided by the CBDC backend system.

Sync.Wall.Req.4 During synchronisation, the wallet SHALL ensure that the locally stored information about all currently supported versions of CBDC notes and their respective update and minimum support periods is up to date with the information provided by the CBDC backend system.

Sync.Wall.Req.5 All information that the wallet receives during synchronisation SHALL be stored locally. The authenticity and integrity of this information SHALL be protected by appropriate cryptographic measures, e.g. following the recommendations in TR-02102 [3].

Sync.Wall.Req.6 During synchronisation, the wallet SHALL send to the CBDC backend system the reports on all failed validity checks that have been detected since the last synchronisation. After the reports have been successfully transmitted, the wallet MAY delete them from its local memory.

Sync.Wall.Req.7 The synchronisation process SHALL be executed using secure communication in conformity with TR Backend [1] (3.3.5). In particular, the synchronisation process SHALL be aborted if the wallet cannot verify the authenticity of the CBDC backend system on a sufficiently high level of assurance. The user SHOULD be informed if the synchronisation process could not be carried out.

Sync.Wall.Req.8 The wallet SHALL provide to the user information about the validity period of the locally stored key material referred to in Sync.Req.3. It SHALL explicitly and in good time warn the user that an online synchronisation is due before any of these keys become invalid.

3.6.4 Rationale

Objective	Covered by	Rationale
Sync.Wall.Obj.1	Sync.Wall.Req.1 Sync.Wall.Req.3 Sync.Wall.Req.4 Sync.Wall.Req.5	Sync.Wall.Obj.1 requires that the wallet is equipped with all relevant information that is needed to operate as intended even when there is no online connection. According to TR Backend [1], this information consists of key material as covered by Sync.Wall.Req.3 and version information as covered by Sync.Wall.Req.4. Sync.Wall.Req.1 ensures that this information is regularly updated, and Sync.Wall.Req.5 ensures that its integrity and authenticity are protected.
Sync.Wall.Obj.2	Sync.Wall.Req.6	Sync.Wall.Obj.2 requires that the CBDC backend system is informed about any suspicious behaviour that occurred during offline times. This is covered by Sync.Wall.Req.6.
Sync.Wall.Obj.3	Sync.Wall.Req.1 Sync.Wall.Req.2	Sync.Wall.Obj.3 requires a reasonable synchronisation frequency. Sync.Wall.Req.1 defines only a minimum frequency, which leaves room for adjustments, e. g. to certain use cases or to performance issues. Sync.Wall.Req.2 covers the case of wallets with a high transaction load. For these, a higher synchronisation frequency is recommended because it is to be expected that more material needs to be reported to the CBDC backend system.
Sync.Wall.Obj.4	Sync.Wall.Req.8	Sync.Wall.Obj.4 requires that the user is aware of the implications that neglected synchronisation may have. This is covered by Sync.Wall.Req.8.

Table 13: Rationale for the objectives of 3.6 ‘Synchronisation with the CBDC backend system’

Threat	Covered by	Rationale
Sync.Wall.Thr.1	Sync.Wall.Req.1 Sync.Wall.Req.3 Sync.Wall.Req.4 Sync.Wall.Req.5	Sync.Wall.Thr.1 concerns the threat of incorrect offline validity checks due to missing or outdated local information. According to TR Backend [1], relevant information consists of key material as covered by Sync.Wall.Req.3 and version information as covered by Sync.Wall.Req.4. Sync.Wall.Req.1 ensures that this information is regularly updated, and Sync.Wall.Req.5 ensures its integrity and authenticity.
Sync.Wall.Thr.2	Sync.Wall.Req.1 Sync.Wall.Req.8	Sync.Wall.Thr.2 concerns the threat that missing synchronisation with the backend leads to a temporary disabling of offline functionality according to TR Backend [1] (Pay.Req.7.Off). The risk is mitigated by providing transparent information and warnings to the user, which is covered by Sync.Wall.Req.8, and by enforcing regular synchronisations, which is covered by Sync.Wall.Req.1.
Sync.Wall.Thr.3	Sync.Wall.Req.6	Sync.Wall.Thr.3 concerns the threat that the CBDC backend system cannot properly monitor suspicious behaviour due to missing reports from the wallets. This is prevented by Sync.Wall.Req.6.
Sync.Wall.Thr.4	Sync.Wall.Req.1	Sync.Wall.Thr.4 concerns the threat that frequent synchronisation slows down the wallet performance. This is mitigated by Sync.Wall.Req.1, which allows that a certain amount of time may elapse before a new synchronisation is required.
Sync.Wall.Thr.5	Sync.Wall.Req.7	Sync.Wall.Thr.5 concerns the threat that the synchronisation process is misused by an attacker. This is prevented by Sync.Wall.Req.7.

Table 14: Rationale for the threats of 3.6 ‘Synchronisation with the CBDC backend system’

3.7 Update

This section of the TR is about the update function of CBDC notes and of the wallet software.

In order to remain functional and up-to-date in terms of security, it is necessary that wallet providers react promptly whenever the central bank announces new CBDC versions so that updates can be implemented in the wallets without undue delay. At the same time, high usability and user acceptance can only be achieved by a maximum validity of old versions of both wallets and CBDC notes. The requirements on update periods, minimum support periods and rules for backward compatibility that are defined in TR Backend aim at striking a balance between the necessity of timely updates and practical restrictions on their immediate implementation. Wallet providers need to make sure that their products are in conformity with these requirements.

The same high security requirements apply to the initiation and implementation of updates as for setting up a wallet. This means that, when performing the update, care must be taken to ensure that the attack vectors, which specifically target the update process, are effectively countered. In particular, if updates of CBDC notes are designed as in-place updates—i. e. legacy CBDC notes are modified by the wallet in such a way that they match the new specification—it must be ensured that this process does not open the possibility of injecting additional and possibly malicious modifications to the CBDC notes. If updates are designed as replacements—i. e. the user sends legacy CBDC notes to the central bank and in turn receives fresh CBDC notes of the same value—it must be ensured that the process does not leak any personal information.

3.7.1 Objectives

- Upd.Wall.Obj.1 Wallets SHALL support all current CBDC versions.
- Upd.Wall.Obj.2 Wallet providers SHALL ensure a timely and appropriate reaction to any security incident that affects the wallets.
- Upd.Wall.Obj.3 Authenticity and integrity of any update SHALL be verified before its application.
- Upd.Wall.Obj.4 Users SHALL confirm the application of updates of both wallet software and CBDC notes.
- Upd.Wall.Obj.5 Users SHALL be informed of available updates of both wallet software and CBDC notes, about update periods and about the consequences of missing out necessary updates.
- Upd.Wall.Obj.6 The level of security SHALL be maintained at all times during the implementation of an update. This applies in particular to updates of the wallet software and to in-place updates of CBDC notes.
- Upd.Wall.Obj.7 When updating CBDC notes, the confidentiality of sensitive information such as personal data or information about critical security issues SHALL be preserved. This applies in particular to updates by replacement, in which personal data SHALL NOT be transmitted to third parties.
- Upd.Wall.Obj.8 The wallet MAY log update processes to inform the wallet provider in case of failures.

3.7.2 Threats

- Upd.Wall.Thr.1 An update leads to inconveniences or severe negative effects for the user, such as the necessity to set up the wallet again, the deletion of the transaction history or, in the worst case, the loss of CBDC notes.
- Upd.Wall.Thr.2 A vulnerability of CBDC notes, wallet software or operating system is exploited before a security update is available and applied.
- Upd.Wall.Thr.3 An attacker keeps a wallet offline to deliberately prevent security updates so that he can exploit weaknesses.
- Upd.Wall.Thr.4 CBDC notes that are not updated within the update period will become invalid and possibly worthless. This will particularly affect users who use their wallet only rarely.
- Upd.Wall.Thr.5 A wallet receives a CBDC note it does not support. This can lead to incompatibilities and to discontinuations of transactions.
- Upd.Wall.Thr.6 An attacker misuses the update process for attacks, for example by providing unauthorised updates or by exploiting other vulnerabilities during the application of the update.
- Upd.Wall.Thr.7 The update mechanism may result in personal data being made public to third parties.

3.7.3 Requirements

- Upd.Wall.Req.1 The process of updating CBDC notes SHALL be in conformity with TR Backend [1], 3.1.6.
- Upd.Wall.Req.2 In particular, wallets SHALL support all versions of CBDC notes for which the minimum support period has not yet expired and SHOULD support all versions until the end of their respective update period, unless otherwise stated in the backward compatibility rules (cf. TR Backend [1], Upd.Req.7). After the end of this update period, CBDC notes of legacy versions SHALL NOT any longer be supported by wallets or be used in transactions (see also the discussion in TR Backend [1], 3.1.6).
- Upd.Wall.Req.3 Wallet providers SHALL receive information about upcoming updates for CBDC notes from the CBDC backend system. The wallet provider SHALL verify the authenticity and integrity of the received information.
- Upd.Wall.Req.4 Wallets SHALL always be updated without undue delay when the central bank releases new CBDC note specifications. In order to guarantee a timely reaction, wallets SHALL be updatable with regard to the cryptographic operations used. For example, it SHALL be possible to switch to a newer encryption technique without any effort on the part of the user.
- Upd.Wall.Req.5 In conformity with the requirements in 3.9 ‘Wallet provider’, wallets SHALL be revised regularly, at the latest when new security aspects arise. In the event of a vulnerability becoming known, wallet providers SHALL take appropriate measures until this gap is closed, which best mitigate the exploitation of this vulnerability.
- Upd.Wall.Req.6 Software wallets SHALL also check whether the operating system on which the wallet is installed is up-to-date. The user SHALL be informed if this is not the case. Depending on the criticality, the wallet MAY deny further transactions until the operating system is updated.
- Upd.Wall.Req.7 A wallet SHALL inform the user when updates of the wallet software are available and SHALL offer an easy method of application. Before the wallet update is applied, the user SHALL be asked for confirmation. A user MAY postpone the application if he or she has been informed about the consequences and confirms understanding. Consequences MAY include that the wallet can no longer be used for transactions until the update has been applied.
- Upd.Wall.Req.8 Before wallet updates are applied, the authenticity and integrity of the update SHALL be verified.
- Upd.Wall.Req.9 The wallet SHALL inform the user when for some CBDC notes in the wallet, a new version is available and SHALL offer an easy method of updating the affected CBDC notes. The user SHALL be informed about the update period during which these CBDC notes SHALL be updated and that any CBDC note that is not updated before the end of the update period will lose its validity. If the update for the CBDC notes is not security-critical and the update period is not halfway over, the user MAY be given the choice to postpone the update once.
- Upd.Wall.Req.10 If a wallet update is released as reaction to a new CBDC version, the user SHALL be given the opportunity to update his or her CBDC notes along with the wallet. Information as in Upd.Wall.Req.9 apply. In case of expected incompatibilities between the available wallet update and the version of CBDC notes that are currently stored in the user’s wallet, the user SHALL further be informed that the wallet update cannot be applied if the CBDC notes are not updated at the same time. If, in this case, the user rejects the update of the CBDC notes, the wallet update SHALL abort.
- Upd.Wall.Req.11 The wallet provider SHALL ensure that neither the wallet update nor the update process inadvertently alter existing security mechanisms and settings.
- Upd.Wall.Req.12 The wallet provider SHALL ensure that neither the wallet update nor the update process on the wallet lead to the loss of CBDC notes, of account-specific data (e.g. transaction histories) or of individually stored information (e.g. recipients’ addresses).
- Upd.Wall.Req.13 Update processes SHALL NOT leak sensitive data to third parties. In particular, they SHALL NOT provide conclusions about critical security issues in the CBDC notes nor about the financial situation of the users.
- Upd.Wall.Req.14 In case of in-place updates for CBDC notes, the update process SHALL NOT allow any changes to the wallet or the CBDC notes that are not strictly required. In particular, the process SHALL NOT change owner or value of the affected CBDC notes and SHALL in general be hardened against injection of fraudulent note data. The update process SHALL provide a cryptographically verifiable proof that only approved changes have been made.

Upd.Wall.Req.15 In case of replacement updates for CBDC notes—i. e. when the update process consists of two or more transactions between the user and an exchange point—the process SHALL be designed as an all-or-nothing protocol as laid down in TR Backend [1] (Upd.Req.9). The user SHALL verify the authenticity of the exchange point before starting the update.

Upd.Wall.Req.16 The wallet SHOULD maintain a log of all in-place updates. It MAY maintain a log of all replacement updates. In case of failures, the wallet provider SHOULD be informed.

3.7.4 Rationale

<i>Objective</i>	<i>Covered by</i>	<i>Rationale</i>
Upd.Wall.Obj.1	Upd.Wall.Req.2 Upd.Wall.Req.3	Upd.Wall.Obj.1 requires that all current CBDC notes be supported. This is covered directly by Upd.Wall.Req.2. In order to meet Upd.Wall.Req.2, it is also necessary that wallet providers are aware of upcoming changes and that they update their wallets accordingly. This is covered by Upd.Wall.Req.3.
Upd.Wall.Obj.2	Upd.Wall.Req.4 Upd.Wall.Req.5 Upd.Wall.Req.6	Upd.Wall.Obj.2 requires a timely and appropriate reaction whenever security incidents become evident that affect the wallets. Upd.Wall.Req.4 addresses the reaction to changes in the CBDC specifications. Upd.Wall.Req.5 addresses the reaction to detected vulnerabilities in the wallet software. Upd.Wall.Req.6 addresses the reaction to an outdated operating system.
Upd.Wall.Obj.3	Upd.Wall.Req.3 Upd.Wall.Req.8 Upd.Wall.Req.15	Upd.Wall.Obj.3 requires that only trusted updates are applied. This is addressed by the authenticity checks in Upd.Wall.Req.3, Upd.Wall.Req.8 and Upd.Wall.Req.15.
Upd.Wall.Obj.4	Upd.Wall.Req.7 Upd.Wall.Req.9 Upd.Wall.Req.10	Upd.Wall.Obj.4 requires that users confirm the application of updates. This is covered by Upd.Wall.Req.7 in the case of wallet updates and by Upd.Wall.Req.9 and Upd.Wall.Req.10 in case of CBDC note updates.
Upd.Wall.Obj.5	Upd.Wall.Req.7 Upd.Wall.Req.9 Upd.Wall.Req.10	Upd.Wall.Obj.5 requires transparency about all updates. Upd.Wall.Req.7 covers the information obligation concerning wallet updates. Upd.Wall.Req.9 and Upd.Wall.Req.10 cover updates of CBDC notes.
Upd.Wall.Obj.6	Upd.Wall.Req.11 Upd.Wall.Req.14	Upd.Wall.Obj.6 requires that the update process itself does not reduce security or opens new attack vectors. This is covered by Upd.Wall.Req.11 and Upd.Wall.Req.14.
Upd.Wall.Obj.7	Upd.Wall.Req.13	Upd.Wall.Obj.7 requires that the update process does not leak any sensitive data. This is covered by Upd.Wall.Req.13.
Upd.Wall.Obj.8	Upd.Wall.Req.16	Upd.Wall.Obj.8 concerns the possibility of keeping a log of all updates. This is covered by Upd.Wall.Req.16.

Table 15: Rationale for the objectives of 3.7 ‘Update’

<i>Threat</i>	<i>Covered by</i>	<i>Rationale</i>
Upd.Wall.Thr.1	Upd.Wall.Req.1 Upd.Wall.Req.12 Upd.Wall.Req.13 Upd.Wall.Req.14 Upd.Wall.Req.15	Upd.Wall.Thr.1 concerns the threat that updates lead to negative effects for the user. The loss of CBDC notes and of user-specific information is prevented by Upd.Wall.Req.12 and indirectly by the measures referenced in Upd.Wall.Req.14 and Upd.Wall.Req.15. Leakage of sensitive data is prevented by Upd.Wall.Req.13. Availability and scalability issues of the update process are treated in TR Backend [1] as referenced in Upd.Wall.Req.1.

Threat	Covered by	Rationale
Upd.Wall.Thr.2	Upd.Wall.Req.4 Upd.Wall.Req.5 Upd.Wall.Req.6 Upd.Wall.Req.13	Upd.Wall.Thr.2 concerns the threat that vulnerabilities are exploited before updates are applied. This threat is mitigated by Upd.Wall.Req.4, Upd.Wall.Req.5 and Upd.Wall.Req.6 requiring a timely reaction to security-related incidents. Moreover, Upd.Wall.Req.13 prevents that the updates themselves leak information about critical security flaws, which could otherwise be used to attack CBDC notes in circulation that have not yet been updated.
Upd.Wall.Thr.3	Upd.Wall.Req.6 Upd.Wall.Req.7 Upd.Wall.Req.9	Upd.Wall.Thr.3 concerns the threat that an attacker deliberately prevents updates by keeping the wallet offline. This risk is reduced by limits on offline payments as laid down in TR Backend [1] and by Upd.Wall.Req.6, Upd.Wall.Req.7 and Upd.Wall.Req.9, which ensure that updates must be applied as soon as the wallet switches back to online mode.
Upd.Wall.Thr.4	Upd.Wall.Req.9 Upd.Wall.Req.10	Upd.Wall.Thr.4 concerns the threat that CBDC notes may lose their validity if they are not updated in time. This threat is mitigated, but not entirely eliminated, by transparent information to the users as addressed in Upd.Wall.Req.9 and Upd.Wall.Req.10.
Upd.Wall.Thr.5	Upd.Wall.Req.2 Upd.Wall.Req.9 Upd.Wall.Req.10	Upd.Wall.Thr.5 concerns the threat of incompatibilities between wallets and CBDC notes. This is mitigated by Upd.Wall.Req.2, Upd.Wall.Req.9 and Upd.Wall.Req.10, which make sure that CBDC notes are kept up-to-date and are supported by all wallets.
Upd.Wall.Thr.6	Upd.Wall.Req.3 Upd.Wall.Req.8 Upd.Wall.Req.11 Upd.Wall.Req.14 Upd.Wall.Req.15	Upd.Wall.Thr.6 concerns the threat that the update process itself can be misused for an attack. This threat is mitigated by Upd.Wall.Req.3 and Upd.Wall.Req.8, which ensure the authenticity of the updates, by Upd.Wall.Req.11 and Upd.Wall.Req.14, which prevent malicious side-effect of the update process. Further, Upd.Wall.Req.14 and Upd.Wall.Req.15 prevent that CBDC note get lost or stolen during the update process.
Upd.Wall.Thr.7	Upd.Wall.Req.13	Upd.Wall.Thr.7 concerns the leakage of personal data during the update process. This is covered by Upd.Wall.Req.13.

Table 16: Rationale for the threats of 3.7 ‘Update’

3.8 Wallet Accounting

This chapter describes the requirements for managing the account and safekeeping of CBDC notes. The management and storage of CBDC notes are central components for the professional and secure handling of CBDC notes in the individual wallet.

Various information must be stored (temporarily) to prove the legality of holding CBDC notes and account balances. With this information, it must be possible to clearly describe the possession of CBDC notes as a whole. As part of a transaction, the transfer of ownership of the CBDC note to the recipient must be confirmed by the sender and the relationship between the note and the previous ownership claims must be changed. However, the transaction can only be executed if the payment is sufficiently covered.

Preventing unauthorised and unintended changes to CBDC notes, as an essential protection goal of the CBDC ecosystem, must be ensured across all processes. When storing CBDC notes, integrity must therefore be kept at an appropriately high level of protection and all sensitive data must be protected by special safeguard.

To prevent a primitive form of double spending, wallets must not have any functionality to copy CBDC notes, not even with the help of a backup function.

In order to increase the availability of offline transactions, some data must be integrated into the wallets provided in an online scenario by the confirmation authority. For example, this data contains information on whether the CBDC note’s version is currently supported (see TR Backend [1], 3.2.2). Conversely, some operations executed by the wallets need to be buffered locally and communicated to the CBDC backend

system on the next opportunity. Examples of temporarily stored information are log files of failed validity checks and any abusive actions that are detected. For this, it is necessary to log and report anomalies and as described in 3.6 ‘Synchronisation with the CBDC backend system’.

3.8.1 Objectives

- Acc.Wall.Obj.1 Wallets SHALL take care of the management and storage of the CBDC notes (TR Backend [1] Purp.Obj.5 and Purp.Req.8).
- Acc.Wall.Obj.2 Software wallets SHOULD provide additional functionality for convenience.
- Acc.Wall.Obj.3 Information about the wallet, in particular about the CBDC notes currently stored in a wallet or any of its subwallets and about the wallet’s transaction history, SHALL be easily accessible to the owner of the wallet.
- Acc.Wall.Obj.4 The integrity, confidentiality and authenticity of wallets, account balances and CBDC notes SHALL be ensured.
- Acc.Wall.Obj.5 Sensitive data SHALL be protected.

3.8.2 Threats

- Acc.Wall.Thr.1 The integrity or confidentiality of CBDC notes and sensitive data is lost, for example an unauthorised person has access to the wallet.
- Acc.Wall.Thr.2 An attacker duplicates the CBDC notes in a wallet.
- Acc.Wall.Thr.3 An attacker circumvents double spending protections by cloning the wallet as a whole.
- Acc.Wall.Thr.4 CBDC notes are deleted or otherwise lost by accident.
- Acc.Wall.Thr.5 Sensitive internal wallet data, e. g. ID, expiration date or holding limit, is manipulated.
- Acc.Wall.Thr.6 The display is manipulated to display fake wallet contents, e. g. an incorrect account balance.
- Acc.Wall.Thr.7 Due to a lack of transparency, the content or balance of a wallet is not transparent to the owner.

3.8.3 Requirements

- Acc.Wall.Req.1 Wallets SHALL store the CBDC notes that it receives and that have passed the validity check (cf. TR Backend [1] 3.2.2 and Txn.Req.6). Invalid CBDC notes SHALL NOT be stored.
- Acc.Wall.Req.2 For the CBDC ecosystem, the central bank defines the set of all possible denominations for CBDC notes (see TR Backend [1], 3.3.14) to define which units of CBDC notes can be transferred and stored. Wallets SHALL be able to manage, store and aggregate these units. Any possible amount SHALL be transferable between two wallets.
- Acc.Wall.Req.3 Software wallets MAY provide additional functionality for organising upcoming payments (cf. Gen.Wall.Obj.10). This MAY include the maintenance of a list of transaction templates and of frequent recipients (cf. Pay.Tran.Req.4). Such lists SHALL be treated as sensitive data.
- Acc.Wall.Req.4 Wallets SHALL base the security of sensitive data on a secure hardware anchor. This includes that they SHALL ensure that access to and integrity and completeness of the stored data is in compliance with the requirements in 3.2 ‘Hardware and interfaces’. In particular, this SHALL apply to CBDC notes. This SHALL also apply to sensitive internal wallet data, such as ID, expiration data and holding limit.
- Acc.Wall.Req.5 Wallets SHALL ensure confidentiality by storing sensitive or personal data in encrypted form or in an equally secure hardware element. The cryptographic protocols, algorithms and parameters used for the encryption SHALL comply with state-of-the-art recommendations, e. g. TR-02102-1 [3].
- Acc.Wall.Req.6 Wallets SHALL provide information about the current status of any of its subwallets. This information SHALL be treated as sensitive data and SHOULD include
- a) the subwallet’s current account balance,
 - b) the transaction history,
 - c) information about transactions in conformity with Pay.Tran.Req.9,
 - d) the expiration date of each CBDC note,
 - e) logs of recently applied updates (see Upd.Wall.Req.16), and

- f) where applicable, current information indicating to what extent the maximum number of consecutive offline payments is exhausted.

This information MAY be maintained or cleared by the wallet owner.

Acc.Wall Req.7 The information in Acc.Wall Req.6 SHALL be easily accessible for the wallet owner. For displaying this information, wallets SHALL use a device in compliance with 3.2 'Hardware and interfaces', which MAY be an external device.

Acc.Wall Req.8 The wallet SHALL NOT provide any functionality for copying CBDC notes (see Hard.Wall.Obj.3). In particular, there SHALL NOT exist any backup features for lost CBDC notes based on keeping copies of CBDC notes on separate storage media, as this would pose the risk of double spending.

3.8.4 Rationale

Objective	Covered by	Rationale
Acc.Wall.Obj.1	Acc.Wall Req.1 Acc.Wall Req.2	Acc.Wall.Obj.1 requires that wallets contain functionality for managing and storing CBDC notes. Acc.Wall Req.1 covers the storage. Acc.Wall Req.2 covers technical prerequisites.
Acc.Wall.Obj.2	Acc.Wall Req.3	Acc.Wall.Obj.2 requires that wallets allow a convenient handling of accounts and payments. Such functionality and maintenance options are covered by Acc.Wall Req.3.
Acc.Wall.Obj.3	Acc.Wall Req.7	Acc.Wall.Obj.3 requires that the wallet's contents are transparent to its owner. This is covered by Acc.Wall Req.7.
Acc.Wall.Obj.4	Acc.Wall Req.4 Acc.Wall Req.5	Acc.Wall.Obj.4 requires that wallet contents are protected. Acc.Wall Req.4 ensures integrity protection. Acc.Wall Req.5 ensures confidentiality.
Acc.Wall.Obj.5	Acc.Wall Req.5	Acc.Wall.Obj.5 concerns the confidentiality of sensitive data. This is covered by Acc.Wall Req.5.

Table 17: Rationale for the objectives of 3.8 'Wallet Accounting'

Threat	Covered by	Rationale
Acc.Wall.Thr.1	Acc.Wall Req.4 Acc.Wall Req.5	Acc.Wall.Thr.1 concerns the loss of integrity or confidentiality. Acc.Wall Req.4 ensures integrity and Acc.Wall Req.5 ensures confidentiality of stored sensitive data.
Acc.Wall.Thr.2	Acc.Wall Req.8	Acc.Wall.Thr.2 concerns the threat that CBDC notes are duplicated. Acc.Wall Req.8 ensures that there is no functionality given by the wallet for copying CBDC notes.
Acc.Wall.Thr.3	Acc.Wall Req.4	Acc.Wall.Thr.3 concerns the threat that an attacker clones the entire wallet. This is mitigated by the use of hardware-based security measures as required by Acc.Wall Req.4.
Acc.Wall.Thr.4	Acc.Wall Req.4	Acc.Wall.Thr.4 concerns the threat that CBDC notes are deleted by accident. This is prevented by Acc.Wall Req.4, which ensures integrity and completeness of CBDC notes.
Acc.Wall.Thr.5	Acc.Wall Req.4	Acc.Wall.Thr.5 concerns the threat that sensitive internal wallet data is manipulated. This is prevented by Acc.Wall Req.4 and the hardware measures referenced therein.
Acc.Wall.Thr.6	Acc.Wall Req.7	Acc.Wall.Thr.6 concerns the threat that the display used to shown the wallet content is manipulated. Acc.Wall Req.7 ensures that a device is used that is in conformity with this TR.
Acc.Wall.Thr.7	Acc.Wall Req.7	Acc.Wall.Thr.7 concerns a lack of transparency towards the user. Acc.Wall Req.7 ensure that all information, in particular the value of the account balance is transparent to the owner.

Table 18: Rationale for the threats of 3.8 'Wallet Accounting'

3.9 Wallet provider

A wallet provider is a company or other entity that provides a CBDC wallet (i. e. a software application or other medium) for holding, storing and transferring CBDC notes.

Wallets allow user to participate in the CBDC ecosystem by enabling CBDC transactions to be carried out and by providing storage and transaction security. At best, all CBDC wallets can interact with each other. It is hence the wallet provider's task to ensure interoperability and to be a point of trust in the deployment of CBDC wallets.

In fact, wallet providers must be trusted participants of the entire CBDC ecosystem and act as the link to the CBDC backend. For example, since offline payments take place without notice of the CBDC backend system, the responsibility for their security cannot lie with the central bank alone. The wallet providers play a crucial role in supporting the central bank in detecting malicious behaviour and in implementing protection against it.

Below are requirements for the wallet provider to strengthen security in this area.

3.9.1 Objectives

- Prov.Wall.Obj.1 Wallet providers SHALL be approved by a competent authority.
- Prov.Wall.Obj.2 Wallet providers SHALL cooperate with the central bank and other competent authorities in protecting the security of the CBDC payment system.
- Prov.Wall.Obj.3 Wallet providers SHALL have an adequate security concept including backup and restore mechanisms, recovery plans, emergency tests.
- Prov.Wall.Obj.4 The wallet provider SHALL implement in its solution all required security features and SHALL provide necessary updates in a timely manner.
- Prov.Wall.Obj.5 The wallet provider SHALL provide accessible terms and conditions.
- Prov.Wall.Obj.6 The wallet provider SHALL inform users about the security-critical properties of the wallet and SHALL keep them informed about security-critical incidents, provided they are relevant to the users.

3.9.2 Threats

- Prov.Wall.Thr.1 The user acceptance of a wallet solution suffers from a lack of trust, transparency or usability.
- Prov.Wall.Thr.2 Security-critical functions or deficiencies in the wallet are exploited, possibly over a long period of time.
- Prov.Wall.Thr.3 An internal offender uses his knowledge for the purpose of a systematic attack on the wallet infrastructure.
- Prov.Wall.Thr.4 Wallets pose a threat to the whole CBDC payment system because the wallet providers do not sufficiently cooperate with the CBDC backend system.
- Prov.Wall.Thr.5 The CBDC payment system cannot be used as intended because the wallet providers do not sufficiently cooperate with the CBDC backend system.

3.9.3 Requirements

- Prov.Wall Req.1 Wallet providers and their wallet solutions SHALL be approved by a competent authority. The wallet providers SHALL provide to this competent authority all information that is necessary for a thorough evaluation of their wallet solution and for assessing the conformity with this TR.
- Prov.Wall Req.2 The wallet provider SHALL have a security concept for its wallet solution. The security concept SHALL be in conformity with established recommendations, e. g. BSI Standard 200-1 [13]. It SHALL address all relevant aspects, and the solution SHALL be tailored to the concept. In particular, the wallet provider SHALL set up and document an appropriate authentication policy for the access and use of the wallet. This policy SHALL be in compliance with 3.3 'Authentication and authorisation'. When selecting employees, it is also important to pay attention to whether a person can be assigned a security-sensitive activity or whether there are actual indications that there are against a transfer of such activities. The criteria should be laid down in this concept.

- Prov.Wall.Req.3 The wallet provider SHALL provide the user with general information on how to use the wallet. In this context, information on the possible use cases in which the wallet can be used and general limitations, such as holding limits, SHOULD also be published.
- Prov.Wall.Req.4 The wallet provider SHALL provide accessible terms and conditions for the use of the wallet. In particular, the general terms and conditions SHALL address the general risks of using the wallet and of participating in transactions, and SHALL clarify the privacy policy.
- Prov.Wall.Req.5 In case of smart cards or other self-contained hardware wallets, the wallet provider SHALL inform the user about expiry dates (cf. 3.2 'Hardware and interfaces').
- Prov.Wall.Req.6 The wallet provider SHALL inform the user about the terms and limitations of offline transactions (TR Backend [1], Pay.Req.7.Off). In particular, it SHALL be made transparent to the user which functions of a wallet are still executable in an offline scenario and, more general, in the event of technical restrictions. Moreover, the user SHALL be informed within the terms and conditions that not all security mechanisms of the backend can take place in the context of an offline transaction.
- Prov.Wall.Req.7 The wallet provider SHALL regularly collect information about upcoming CBDC updates from the central bank through the designated communication channels (cf. TR Backend [1], Upd.Req.4 and Doc.Req.7).
- Prov.Wall.Req.8 The wallet provider SHALL continuously gather information on security vulnerabilities applicable for its wallet solutions. To this effect, it SHOULD regularly check relevant sources, e. g. the security advisories of the German Federal Office for Information Security (BSI) and the National Vulnerability Database of the National Institute for Standards and Technology (NIST). The wallet provider SHALL also take into account the logged information according to Upd.Wall.Req.16.
- Prov.Wall.Req.9 If, in the situation of Prov.Wall.Req.7 or Prov.Wall.Req.8, the announcement of CBDC updates or the detection of new vulnerabilities demand that the wallet software is updated, the wallet provider SHALL provide updates as soon as possible and SHALL make sure that they respect the minimum support period and the backward compatibility rules defined by the central bank (see TR Backend [1], Upd.Req.6 and Upd.Req.7).
- Prov.Wall.Req.10 The wallet provider SHALL inform the user when the updates for CBDC notes and wallets are ready for application and about the update period of CBDC notes (cf. TR Backend [1], Upd.Req.4).
- Prov.Wall.Req.11 The wallet provider SHALL cooperate with the central bank regarding threat detection (see TR Backend [1], Mon.Obj.2) and security incidents related to wallets.
- Prov.Wall.Req.12 The wallet provider SHALL support the central bank in blocking suspicious wallets (see Dis.Wall.Req.9 and TR Backend [1], Mon.Req.5) by making sure that their wallets do not accept payments to or from blocked wallets (see Dis.Wall.Req.9). In particular, the wallet provider SHALL use best efforts to provide the wallets with necessary information to identify blocked wallets even in an offline scenario.
- Prov.Wall.Req.13 In order to avoid mishandling, care SHOULD be taken to ensure that the user journey of the product meets the current standards and thus enables risk-free handling.

3.9.4 Rationale

<i>Objective</i>	<i>Covered by</i>	<i>Rationale</i>
Prov.Wall.Obj.1	Prov.Wall.Req.1	Prov.Wall.Obj.1 requires that wallet providers are approved. This is covered by Prov.Wall.Req.1.
Prov.Wall.Obj.2	Prov.Wall.Req.1 Prov.Wall.Req.7 Prov.Wall.Req.9 Prov.Wall.Req.10 Prov.Wall.Req.11 Prov.Wall.Req.12	Prov.Wall.Obj.2 requires cooperation from the wallet providers. Prov.Wall.Req.1 ensures cooperation in the security assessment of their wallet solution. Prov.Wall.Req.7, Prov.Wall.Req.9 and Prov.Wall.Req.10 ensure cooperation in the maintenance of CBDC updates. Prov.Wall.Req.11 and Prov.Wall.Req.12 ensure cooperation in the detection and mitigation of security incidents.
Prov.Wall.Obj.2	Prov.Wall.Req.2	Prov.Wall.Obj.2 requires that wallet providers have an adequate security concept. This is covered by Prov.Wall.Req.2.
Prov.Wall.Obj.3	Prov.Wall.Req.1 Prov.Wall.Req.7	Prov.Wall.Obj.3 requires that wallet providers implement and maintain all required security features. Conformity with this TR

Objective	Covered by	Rationale
	Prov.Wall.Req.8 Prov.Wall.Req.9	as required by Prov.Wall.Req.1 ensures that the required features are implemented. Prov.Wall.Req.7, Prov.Wall.Req.8 and Prov.Wall.Req.9 ensure that vulnerabilities are detected and updates provided.
Prov.Wall.Obj.5	Prov.Wall.Req.3 Prov.Wall.Req.4 Prov.Wall.Req.5 Prov.Wall.Req.6	Prov.Wall.Obj.5 requires that wallet providers provide accessible terms and conditions. Information obligations are covered by Prov.Wall.Req.3, Prov.Wall.Req.4, Prov.Wall.Req.5 and Prov.Wall.Req.6.
Prov.Wall.Obj.6	Prov.Wall.Req.4 Prov.Wall.Req.6	Prov.Wall.Obj.6 requires that wallet providers inform the users about risks and security-critical properties of the wallet. Information obligations concerning the risks of using the CBDC payment system are treated in Prov.Wall.Req.4 and Prov.Wall.Req.6.

Table 19: Rationale for the objectives of 3.9 'Wallet provider'

Threat	Covered by	Rationale
Prov.Wall.Thr.1	Prov.Wall.Req.1 Prov.Wall.Req.3 Prov.Wall.Req.4 Prov.Wall.Req.5 Prov.Wall.Req.6 Prov.Wall.Req.10 Prov.Wall.Req.13	Prov.Wall.Thr.1 concerns the threat of poor user acceptance due to deficiencies in the wallet solution. Prov.Wall.Req.1 ensures trust by requiring approved wallet providers. Prov.Wall.Req.3, Prov.Wall.Req.4, Prov.Wall.Req.5, Prov.Wall.Req.6 and Prov.Wall.Req.10 ensure transparency towards the users. Prov.Wall.Req.13 is in place to avoid mishandling.
Prov.Wall.Thr.2	Prov.Wall.Req.7 Prov.Wall.Req.8 Prov.Wall.Req.9	Prov.Wall.Thr.2 concerns the threat that vulnerabilities are exploited or remain undetected. This is prevented by Prov.Wall.Req.7 and Prov.Wall.Req.8 requiring that the wallet provider collects information about necessary security updates, and by Prov.Wall.Req.9 ensuring that these are applied in a timely manner.
Prov.Wall.Thr.3	Prov.Wall.Req.2	Prov.Wall.Thr.3 concerns the threat of internal attackers.
Prov.Wall.Thr.4	Prov.Wall.Req.1 Prov.Wall.Req.7 Prov.Wall.Req.9 Prov.Wall.Req.11 Prov.Wall.Req.12	Prov.Wall.Thr.4 concerns the threat which uncooperative wallet providers may pose to the entire CBDC payment system. Prov.Wall.Req.1 ensures that the wallet provider cooperates in assessing the security of the wallet solution. Prov.Wall.Req.7 and Prov.Wall.Req.9 ensure that the wallet provider cooperates in the application of updates. Prov.Wall.Req.11 and Prov.Wall.Req.12 ensure that the wallet provider cooperates in the threat detection and blocking of malicious wallets.
Prov.Wall.Thr.5	Prov.Wall.Req.1 Prov.Wall.Req.9	Prov.Wall.Thr.5 concerns the threat that wallets cannot be used as intended due to insufficient cooperation of the wallet provider. Prov.Wall.Req.1 ensures a general conformity of the wallet solution with this TR. Prov.Wall.Req.9 obliges the wallet providers to heed compatibility rules.

Table 20: Rationale for the threats of 3.9 'Wallet provider'

4 Transactions

The area of transaction includes payment and validity check. Corresponding requirements can be found in the sub-chapters.

In the payment process, it is still necessary to clarify how the user receives the recipient's ID. According to the type of messenger services, it is conceivable to use the mobile phone number corresponding to the mobile device. Information such as the IBAN (International Bank Account Number) could also be used in banking.

Transactions include payment, distribution and exchange.

4.1 Payment

Paying with CBDC notes is expected to work much like contactless paying with an NFC-enabled bank card. A wallet – as an app on a mobile device or as a hardware token – will be needed. Such a wallet can either be connected to another payment method or bank account, or it could be charged with CBDC notes like a prepaid card and would in this form also be usable by unbanked persons, children etc.

For payments that do not run through a POS system, the user may select the desired recipient from his or her stored contacts or may enter the receiving wallet's identification number directly, similar to the IBAN in banking. A mobile number of the recipient would also be conceivable to identify the recipient. When using mobile devices, a QR code can be scanned and the recipient data can be recorded. In a further step, the amount and type of transaction is selected or entered and possibly a subject or message. The entered data is displayed on the display – if any – and confirmed by the user.

While this TR demands that each transaction must be confirmed after the sender has read the transaction details, it does not require that the confirmation must be given through the sender's device. Depending on the use case, it is also conceivable that the sender enters a PIN or similar directly on the payment terminal of the receiver. Moreover, the TR does not explicitly exclude the possibility that the confirmation is given only implicitly. For example, a user at a POS checks the payment details displayed on the payment terminal by visual inspection, then gives his approval by placing an activated wallet to the terminal's reader.

At any time before confirmation, the transaction can be cancelled by the user. Only after confirmation, it is carried out. The mechanisms explained in TR Backend will then ensure a secure execution of the transaction, for example, by requiring that authentication measures and the encryption of the transactions must correspond to the state of the art, and that a completed transaction cannot be revoked since the sender no longer has access to the transferred CBDC notes.

In the above described payment scenarios, an important aspect is that transaction details are made transparent to the sender and the recipient. Each participant in a transaction must know which transaction will take or has taken place, what data is to be or has been exchanged, and whether it is an online transaction or whether it is an offline transaction, that only can implement lower protection measures. By showing all the details of the transaction to the sender, they can cancel the transaction if it seems incorrect. By showing the details to the recipient, they are informed that the value of the CBDC note is credited to their wallet, but also, in the case of an offline payment, that not all security mechanisms of the backend will immediately apply. Note that the requirements in this TR do not ensure that the date and time, which are included in the transaction details, are always reliable. They may serve for information purposes and to sort the transaction history. However, for use cases where a reliable timestamp is needed, additional measures, such as qualified electronic timestamps, must be included, which may not be compatible with offline payments.

Also note that transparency in the above sense may not be practicable in other use cases. Consider, for example, transactions in an M2M context, where displaying the transaction details and waiting for active confirmation may be rather nonsensical. Depending on the specific situation, it may be better just to maintain a detailed log file for later inspection. However, since this TR focusses on P2P use cases, such adaptations to the M2M context are out of scope of the following chapters.

4.1.1 Objectives

Pay.Tran.Obj.1 Transactions SHALL be possible between all wallets that are designated for the respective transaction type.

- Pay.Tran.Obj.2 The receiver's ID and the amount to be transferred SHALL be specified. The sender MAY choose additional transaction options. The sender SHALL confirm each transaction before execution.
- Pay.Tran.Obj.3 The risk of performing unintended transactions amounts SHALL be minimised.
- Pay.Tran.Obj.4 Before a transaction is executed, it SHALL be verified that the receiver's wallet can accept the CBDC notes that are to be sent. In particular, it SHALL be verified that the wallet supports the CBDC notes' versions and does not exceed any holding limits.
- Pay.Tran.Obj.5 Transactions SHALL be processed in conformity with TR Backend [1], in particular with respect to authorisation, transparency, and the preference for online over offline validity checks.
- Pay.Tran.Obj.6 All details SHALL be made transparent to the parties involved in the transaction.
- Pay.Tran.Obj.7 Transactions SHALL NOT be interfered with, tampered with, or read.
- Pay.Tran.Obj.8 Both completed transactions and transactions that aborted with a failure SHOULD be logged in the sender's transaction history. Completed transactions SHOULD also be logged in the recipient's transaction history.
- Pay.Tran.Obj.9 Depending on the type of transaction, the strength of authentication SHALL be chosen.
- Pay.Tran.Obj.10 Before a transaction is executed, it SHALL be ensured that the sender's wallet is adequately funded.

4.1.2 Threats

- Pay.Tran.Thr.1 A transaction cannot be executed because the technical infrastructure, such as a card readers or internet connection, is not available.
- Pay.Tran.Thr.2 A CBDC note cannot be used for transactions due to technical incompatibilities between different or outdated versions of CBDC notes, applications or infrastructure.
- Pay.Tran.Thr.3 The transaction that is executed differs from what the sender has or believes to have confirmed, for example, due to a carelessness by the sender or because an attacker manipulates the transaction details.
- Pay.Tran.Thr.4 A transaction of any kind is performed by an entity who is not the owner of the CBDC notes that are spent in this transaction.
- Pay.Tran.Thr.5 The execution of a transaction is interrupted, leaving the payment process or the ownership of the CBDC notes in an unclear state.
- Pay.Tran.Thr.6 An unauthorised third party obtains information on the sender, receiver or value of a transaction.
- Pay.Tran.Thr.7 A CBDC note cannot be used for transactions because its owner lost the secret key that is required for authenticating such transactions. From a technical perspective, such a CBDC note is still valid but cannot be used.

4.1.3 Requirements

- Pay.Tran.Req.1 It SHALL be possible to transfer CBDC notes between any wallet regardless of the provider or the specific implementation. All wallet types SHALL implement the agreed technical communication standards used for mobile banking.
- Pay.Tran.Req.2 If the sender's wallet runs on hardware that is not itself equipped with a display and an input device, a card reader in conformity with 3.2 'Hardware and interfaces' SHALL be used in the transactions.
- Pay.Tran.Req.3 Communication between different wallets and between wallets and terminal devices SHALL use secure channels as laid down in 3.2 'Hardware and interfaces'. Communication between wallets or card readers and the CBDC backend system SHALL be in conformity with TR Backend [1] (3.3.5).
- Pay.Tran.Req.4 The recipient and the amount of a transaction SHALL be specified. There SHOULD exist different methods of how to enter these data (cf. 3.2 'Hardware and interfaces'). For example, the sender MAY select the recipient from a local address list, or the recipient's wallet ID and the amount MAY be entered manually.
- Pay.Tran.Req.5 In addition to the input options in Pay.Tran.Req.4, the recipient MAY provide his or her wallet ID or the amount of the transaction by presenting a QR code or through some other channel. In this case, the communication channel SHOULD be in conformity with Pay.Tran.Req.3 to ensure that the correct amount of CBDC notes is transferred to the intended recipient.

- Pay.Tran.Reg.6** For transactions, different payment-options MAY be available to be chosen by the sender (e. g. storing the recipient's ID in a local address list for future transactions (cf. 3.1 'General functions') or, if implemented in the CBDC design, adding a reference or message to the transaction).
- Pay.Tran.Reg.7** If the CBDC solution includes functionality for offline transactions, transaction protocols SHOULD in principle be executable without an active connection to the CBDC backend system. However, in conformity with TR Backend [1] (3.2.4), transactions SHOULD NOT be executed as offline transactions if an online connection to the confirmation authority can be established. Transactions that are not allowed in an offline scenario SHALL NOT be executed as offline transactions.
- Pay.Tran.Reg.8** If the user initiates an offline transaction, the wallet SHOULD provide information to what extent the limit for consecutive offline transactions is currently exhausted and SHALL explicitly and in good time warn the user that an online payment is due before offline transactions are disabled.
- Pay.Tran.Reg.9** The execution of a transaction SHALL be in conformity with TR Backend [1] (3.2). In particular, transaction details SHALL be made transparent to both sender and recipient; this information includes
- an identifier for the sending account,
 - an identifier for the receiving account,
 - the amount of money which is to be transferred,
 - the date and time of execution,
 - the kind of transaction (payment, distribution, exchange),
 - the connectivity status of the sending and receiving wallet.
- Moreover, the sender SHALL confirm the transaction and SHALL prove ownership of the CBDC notes to be sent. The receiving wallet SHALL perform a validity check on all transferred CBDC notes (cf. Val.Tran.Reg.1 and TR Backend [1]).
- Pay.Tran.Reg.10** In addition to checking that the versions of the received CBDC notes have not yet expired (cf. TR Backend [1] Val.Reg.5), the receiving wallet SHALL also check whether they are compatible with the versions it currently supports itself. In case of incompatibilities with the version of any of the involved CBDC notes, the transaction SHALL abort.
- Pay.Tran.Reg.11** Before the transaction is executed, the receiving wallet SHALL check whether it can accept the amount of CBDC notes that are to be sent, i. e. that the transaction does not lead to exceeding any holding limits that are in place. If one or more of the involved CBDC notes cannot be accepted, the transaction SHALL abort.
- Pay.Tran.Reg.12** If a transaction is successfully completed, the value of the transferred CBDC notes SHALL be credited to the account balance of the recipient and the wallet or the card reader in use SHALL display a confirmation message. Transactions SHALL not be revocable and SHOULD be logged in both the sender's and the recipient's transaction history. The recipient's wallet SHALL store the transferred notes in conformity with 3.8 'Wallet Accounting'.
- Pay.Tran.Reg.13** If the online connection is lost during the execution of a transaction and if this transaction is not allowed in an offline scenario, it SHALL be aborted. If the transaction is allowed in an offline scenario, the execution MAY continue. In this case, all requirements for offline transactions apply.
- Pay.Tran.Reg.14** If a transaction fails, e. g. due to connectivity or compatibility issues, the original state SHALL be restored as laid down in TR Backend [1] (3.2.4). The wallet or the terminal device in use SHALL display a failure message to the sender that clearly indicates the reason of the abortion. The aborted transaction SHOULD be logged in the sender's transaction history.
- Pay.Tran.Reg.15** For confirming the transaction, the authentication as laid down in 3.3 'Authentication and authorisation' SHALL be in place.
- Pay.Tran.Reg.16** To prevent that the user of the wallet permanently loses access to the wallet or the notes, authentication means SHALL be recoverable according to Auth.Wall.Reg.11.

4.1.4 Rationale

<i>Objective</i>	<i>Covered by</i>	<i>Rationale</i>
Pay.Tran.Obj.1	Pay.Tran.Reg.1 Pay.Tran.Reg.9	Pay.Tran.Obj.1 requires interoperability between all relevant wallets within their scope of application. This is explicitly

Objective	Covered by	Rationale
		covered by Pay.Tran.Req.1 and supported by Pay.Tran.Req.9, which ensures conformity with the general requirements in TR Backend [1].
Pay.Tran.Obj.2	Pay.Tran.Req.2 Pay.Tran.Req.4 Pay.Tran.Req.5 Pay.Tran.Req.6 Pay.Tran.Req.9	Pay.Tran.Obj.2 concerns rules for entering and confirming transaction data by the sender. Pay.Tran.Req.2 ensures that the technical requirements for user interaction are fulfilled. Pay.Tran.Req.4 and Pay.Tran.Req.5 cover the specification of recipient and amount. Pay.Tran.Req.6 covers additional payment options. Pay.Tran.Req.9 ensures that transactions are confirmed before execution.
Pay.Tran.Obj.3	Pay.Tran.Req.3 Pay.Tran.Req.9	Pay.Tran.Obj.3 requires that measures be taken to avoid unintended transactions. Making transaction details transparent and enforcing a confirmation by the sender, as required by TR Backend [1] referenced in Pay.Tran.Req.9, mitigates the risk of careless mistakes. Pay.Tran.Req.3 ensures secure communication between wallets, card readers and the CBDC backend system, which can prevent attackers from altering transaction details before or after confirmation.
Pay.Tran.Obj.4	Pay.Tran.Req.10 Pay.Tran.Req.11	Pay.Tran.Obj.4 requires that potential problems with compatibility or holding limits are detected before the transaction is executed. This is covered by Pay.Tran.Req.10 and Pay.Tran.Req.11.
Pay.Tran.Obj.5	Pay.Tran.Req.9	Pay.Tran.Obj.5 requires conformity with TR Backend [1] while processing transactions. This is directly covered by Pay.Tran.Req.9.
Pay.Tran.Obj.6	Pay.Tran.Req.8 Pay.Tran.Req.9 Pay.Tran.Req.12 Pay.Tran.Req.14	Pay.Tran.Obj.6 requires that transaction details be made transparent to the participating parties. This is covered by TR Backend [1] as referenced in Pay.Tran.Req.9. In addition, success or failure messages are covered in Pay.Tran.Req.12 and Pay.Tran.Req.14, respectively. Pay.Tran.Req.8 ensures that the current status of consecutive offline payments is transparent to the user.
Pay.Tran.Obj.7	Pay.Tran.Req.3	Pay.Tran.Obj.7 concerns the integrity and confidentiality of transactions. These are ensured by Pay.Tran.Req.3.
Pay.Tran.Obj.8	Pay.Tran.Req.12 Pay.Tran.Req.14	Pay.Tran.Obj.8 requires that all confirmed transactions should be logged. The logging of successful transactions is covered by Pay.Tran.Req.12. The logging of aborted transactions is covered by Pay.Tran.Req.14.
Pay.Tran.Obj.9	Pay.Tran.Req.15	Pay.Tran.Obj.9 concerns the strength of the authentication procedures. This is covered by Pay.Tran.Req.15.

Table 21: Rationale for the objectives of 4.1 'Payment'

Threat	Covered by	Rationale
Pay.Tran.Thr.1	Pay.Tran.Req.1 Pay.Tran.Req.7 Pay.Tran.Req.13	Pay.Tran.Thr.1 concerns the threat of missing transaction infrastructure or internet connection. Providing a sufficient number of devices and the necessary infrastructure is not the responsibility of this TR. However, Pay.Tran.Thr.1 is somewhat mitigated by Pay.Tran.Req.1, which increases the interoperability of all existing wallets. Moreover, Pay.Tran.Req.7 and Pay.Tran.Req.13 allow offline transactions in certain situations, which reduces problems arising from a missing internet connection.
Pay.Tran.Thr.2	Pay.Tran.Req.1 Pay.Tran.Req.10	Pay.Tran.Thr.2 concerns the threat of technical incompatibilities. This is covered by Pay.Tran.Req.1.

<i>Threat</i>	<i>Covered by</i>	<i>Rationale</i>
		Incompatibilities between different CBDC versions are covered by Pay.Tran.Reg.10.
Pay.Tran.Thr.3	Pay.Tran.Reg.3 Pay.Tran.Reg.9	Pay.Tran.Thr.3 concerns the threat that a transaction is executed which differs from what the sender expected. Pay.Tran.Reg.9 ensures transparency and explicit confirmation of transactions, which mitigate the risk of careless mistakes. Secure communication between wallets and card readers prevents an attacker from manipulating the transaction data before confirmation. Secure communication between wallets and the CBDC backend system prevents an attacker from manipulating the transaction data after confirmation. Both are covered by Pay.Tran.Reg.3.
Pay.Tran.Thr.4	Pay.Tran.Reg.3 Pay.Tran.Reg.9 Pay.Tran.Reg.15	Pay.Tran.Thr.4 concerns the threat that an unauthorised entity performs a transaction. This is covered by the authentication procedure in Pay.Tran.Reg.3 and Pay.Tran.Reg.15, and the proof of ownership referenced in Pay.Tran.Reg.9.
Pay.Tran.Thr.5	Pay.Tran.Reg.9 Pay.Tran.Reg.12 Pay.Tran.Reg.14	Pay.Tran.Thr.5 concerns the threat that an unexpected interruption leads to an unclear state. The requirements referenced in Pay.Tran.Reg.9 and Pay.Tran.Reg.14 ensure that transactions are eventually atomic, so that they always end in a well-defined state. The success or failure messages in Pay.Tran.Reg.12 and Pay.Tran.Reg.14 ensure that potential uncertainties about the state are clarified.
Pay.Tran.Thr.6	Pay.Tran.Reg.3 Pay.Tran.Reg.9	Pay.Tran.Thr.6 concerns the loss of confidential information. This is covered by Pay.Tran.Reg.3, which ensures secure communication between all involved entities, and by TR Backend [1] as referenced in Pay.Tran.Reg.9.
Pay.Tran.Thr.7	Pay.Tran.Reg.16	Pay.Tran.Thr.7 concerns the threat that CBDC notes cannot be spent because of lost authentication means. This is mitigated by Pay.Tran.Reg.16.

Table 22: Rationale for the threats of 4.1 'Payment'

4.2 Validity check

CBDC notes are subjected to a validity check by the confirmation authority, whenever a transaction is executed online. In addition, wallets may provide functionality to check the CBDC notes' validity independently of a transaction, provided an online connection to the confirmation authority can be established. The validity check aims at detecting possible frauds and double spending. It also verifies that the sender's wallet has not been blocked. While, within the CBDC system, the confirmation authority is the entity that has the most comprehensive overview of security-related activities, this does not relieve wallet providers from their responsibility for implementing measures that counter attacks on the CBDC notes' validity and thus on the trustworthiness of the whole CBDC payment system.

Particularly, in the case of offline transactions, the validity of notes cannot be checked directly as not all backend security measures are available at the time of transaction. Therefore, the execution of offline transactions involves certain risks and the importance of a trustworthy and reliable wallet becomes evident. This includes among others the implementation of specific security measures which ensure that it must not be technically possible to modify or ignore the result of a validity check. Moreover, in order to support the CBDC backend system in detecting malicious wallets, it is necessary that benign wallets regularly submit information about failed validity checks to the confirming authority.

4.2.1 Objectives

- Val.Tran.Obj.1 Wallets SHALL perform validity checks for all CBDC notes in all incoming transactions.
- Val.Tran.Obj.2 Wallets SHALL follow the result of the validity check. In particular, invalid CBDC notes SHALL not be accepted.
- Val.Tran.Obj.3 Wallets SHALL log failed validity checks and report them to the backend system.

Val.Tran.Obj.4 Wallets MAY perform additional validity checks provided an online connection to the confirmation authority can be established.

4.2.2 Threats

Val.Tran.Thr.1 Invalid CBDC notes get into circulation, for example several copies of the same note all of which pass the validity check.

Val.Tran.Thr.2 An attacker gains access to that component of a wallet which is responsible for the validity checks of CBDC notes for offline transactions. The attacker may thus manipulate the results of all future offline validity checks on that particular wallet at will.

Val.Tran.Thr.3 An attacker manipulates the results of online validity checks that are provided by the CBDC confirmation authority.

4.2.3 Requirements

Val.Tran.Req.1 For all incoming transactions and all CBDC notes contained therein, the receiving wallet SHALL check whether the received CBDC notes are valid. The receiving wallet SHALL perform an online check whenever required or possible, or an offline check otherwise; it SHALL follow the details for validity checks as laid down in TR Backend [1].

Val.Tran.Req.2 The wallet SHALL refuse to receive transactions in the event of a negative check result.

Val.Tran.Req.3 If the wallet has an online connection to the confirmation authority, it MAY perform validity checks on the CBDC notes it stores. These checks MAY be initiated on request of the wallet owner or at regular intervals.

Val.Tran.Req.4 It SHALL NOT be possible to manipulate a wallet in such a way that the result of a validity check can be altered or ignored at will.

Val.Tran.Req.5 If a validity check fails, the wallet SHALL log the failure and SHALL report this to the backend system in conformity with 3.6 'Synchronisation with the CBDC backend system' and TR Backend [1].

Val.Tran.Req.6 The communication between wallet and confirmation authority SHALL be secured according to TR Backend [1] (3.3.5).

4.2.4 Rationale

Objective	Covered by	Rationale
Val.Tran.Obj.1	Val.Tran.Req.1	Val.Tran.Obj.1 requires that the receiving wallet verifies the validity of all received CBDC notes. This is covered by Val.Tran.Req.1.
Val.Tran.Obj.2	Val.Tran.Req.2 Val.Tran.Req.4	Val.Tran.Obj.2 requires that the result of the validity check is binding. Val.Tran.Req.2 prohibits that the wallet ignores negative check results. Val.Tran.Req.4 ensures that this prohibition cannot be circumvented.
Val.Tran.Obj.3	Val.Tran.Req.5	Val.Tran.Obj.3 requires that failed validity checks shall be logged and reported. This is covered by Val.Tran.Req.5 and the references therein.
Val.Tran.Obj.4	Val.Tran.Req.3	Val.Tran.Obj.4 states that validity checks may be performed on request of the owner and independently of a transaction. This is covered by Val.Tran.Req.3.

Table 23: Rationale for the objectives of 4.2 'Validity check'

Threat	Covered by	Rationale
Val.Tran.Thr.1	Val.Tran.Req.1 Val.Tran.Req.2 Val.Tran.Req.4	Val.Tran.Thr.1 concerns the risk of invalid CBDC notes getting into circulation. This risk is mitigated by Val.Tran.Req.1 requiring that wallets perform validity checks, and by Val.Tran.Req.2 and Val.Tran.Req.4 making sure that the check results cannot be ignored at will nor through manipulation.

<i>Threat</i>	<i>Covered by</i>	<i>Rationale</i>
Val.Tran.Thr.2	Val.Tran.Req.4	Val.Tran.Thr.2 concerns the threat that an attacker controls the offline validity check of a target wallet. This is covered by Val.Tran.Req.4.
Val.Tran.Thr.3	Val.Tran.Req.4 Val.Tran.Req.6	Val.Tran.Thr.3 concerns the threat that an attacker manipulates the results of online validity checks. Val.Tran.Req.6 ensures that authenticity and integrity of the check results are secured during transmission. Val.Tran.Req.4 ensures that the results cannot be manipulated inside the wallet.

Table 24: Rationale for the threats of 4.2 ‘Validity check’

5 Conclusion

The central bank must make various decisions on the technical implementation of the CBDC and the necessary steps (design of the backend, the frontend, scope of supported payment methods, legal requirements). With the series of guidelines, the BSI is taking a pioneering role as a cyber-security authority of the German federal government by actively addressing the development of IT security requirements for CBDC and by setting essential standards here.

The BSI TR-03179-1 and -2 guidelines are aimed at providers of CBDC systems, for whom they can serve as a guide for a secure implementation in accordance with the 'Security by Design' principle. The TR may also be used as a basis for a later certification process.

The first part of the Technical Guideline deals with the requirements for the backend systems of the CBDC infrastructure operated by the central bank. In addition to general IT security requirements – e. g. cryptographic procedures, IT systems used and physical security – these include, above all, the requirements relevant to the backend system for the specific processes throughout the CBDC lifecycle. Special emphasis is placed on requirements to avoid counterfeiting and double spending.

The present second part of the Technical Guideline focuses on the frontend systems with which end-users interact.

The requirements of the frontend are aimed at manufacturers of software and hardware wallets. When implementing these wallets, various basic security features have to be implemented. Essentially, the requirements are aimed at avoiding unauthorised access to the wallets and preventing the initiation of abusive payments. At the same time, a sensible and secure update management system must be implemented for the wallets in relation to those of the backend. In order to achieve these goals, requirements have to be implemented that secure the entire process from onboarding (initial registration) to performing a transaction in a multi-layered manner. However, the frontend system must not only be secure, it must also be easy to use. The easy usability of the wallets must be given.

In order to appeal to a wide range of users, it is conceivable that a wallet is used in various forms. Wallets can be integrated as an app on a smartphone, as a web frontend or in various form factors such as smart cards or hardware tokens. Due to the heterogeneity of these form factors, some security requirements must be scaled according to the technological framework and implemented according to the possibilities of the form factors.

Annex A: Comparison of CBDC and cash

<i>Property</i>	<i>Cash</i>	<i>CBDC</i>
Required hardware for end users	Robust and durable banknotes and coins provided by the central bank; IT hardware in possession of users <i>not</i> required.	IT hardware with certain security properties (cf. this TR)
Required hardware for financial backend	Secure ATMs, sorting and verification machines	Highly secure IT hardware for operating the CBDC backend system (cf. TR Backend [1])
Requirements on electricity, connectivity for transactions	Generally none	Requires electricity, requires internet connection on a regular basis
Possibility of anonymous transactions	Yes	Depends on implementation. May be provided up to certain amount of money if associated fraud risk is accepted.
Copy protection	Several layers of physical security features	Technical and organisational measures
Robustness to damaging	May be accepted even if soiled, damaged or technically past its validity period.	For security reasons cannot be accepted if integrity is violated or validity period has expired. May become inaccessible and thus unusable if storage hardware is damaged or malfunctioning.
Verification of genuineness	Using physical security features; ultimate confirmation can only be granted by central bank upon request.	Instantaneous if connection to confirmation authority is available.
Scope of individual transactions	Only local	Worldwide (may be subject to political restrictions)

Table 25: Comparison of technical properties of cash and CBDC

Cash	CBDC	Comments on CBDC equivalent
Changing money	Notes of appropriate denomination are generated during a transaction.	Technical process, can be abstracted in user interface
Issuance of updated banknotes and coins containing new security features	Update process for changing cryptographic protection	Update period must be relatively short to prevent scalable attacks. Unlike cash, new security features will not be transparent to users.
Physical destruction	Hardware destroyed, lost or stolen without corresponding authentication factor OR authentication factor destroyed, lost or stolen	Recovery might optionally be possible in this case.
Attachment of debtor's purse can be enforced physically.	Debtor needs to perform transfer of funds.	CBDC does not exist physically. Storage medium can be seized, but stored CBDC cannot be used unless debtor cooperates.
Entrusting cash to third party (e. g. children) for errands	Transfer of appropriate amount of CBDC to other wallet and entrusting this to third party	Entrusting CBDC wallet including authentication factors to third party is technically possible, but gives unlimited power on stored CBDC funds, which carries risk of abuse even in the future.
Carrying reduced amount of cash when attending places with increased risk of theft	Transfer of appropriate amount of CBDC to wallet on separate hardware and carrying this	Carrying hardware containing one's total CBDC funds increases potential loss from theft (regardless of whether thief can actually use CBDC funds stored on this hardware).

Table 26: Comparison of specific actions for cash and CBDC

Glossary

Anonymity

Personal data, i. e. data relating to an identified or identifiable living user, is not used.

Anti-money laundering (AML)

The aim of anti-money laundering is to detect illegally acquired funds and identify suspicious transactions or activities. International co-operation agreements are in place to support these efforts. Some anti-money laundering laws combine money laundering (which relates to the origin of the funds) with terrorist financing (which relates to the destination of the funds) when regulating the financial system.

App

A computer programme or software application that is designed to run on a mobile device.

Blocking

In the event of malicious behaviour, the wallet will be blocked by the CA. This blocking can only be cancelled with the permission and cooperation of the CA.

Central bank

Ultimate responsibility for the IT security of the CBDC system lies with the corresponding central bank. That notwithstanding, in the present document this term may also cover supporting entities to which the central bank delegates responsibility (cf. 2.2.1 ‘Delegation of responsibility’).

CBDC

A central bank liability in digital form offered to the general public for retail payments.

CBDC note

Piece of data representing a certain amount of CBDC, applicable to both token-based and account-based approach (cf. 2.2.4.4 ‘Token-based approach versus account-based approach’). In the account-based approach, an account is treated as one single CBDC note.

Confirmation authority (CA)

Entity controlled by the *central bank* which is responsible for online *validity checks* for *transactions*.

Deactivating

If a wallet is not used for a certain period of time it can be deactivated. This deactivation serves to protect the wallet. Functions that require a regular connection to the backend to receive updates for example, remain unaffected. Deactivation can always be cancelled by the user e. g. by entering a security PIN or by topping up a prepaid wallet.

Distribution

Initial step of putting *CBDC notes* into circulation. CBDC notes created by the *issuer* are transferred to *exchange points* in a *distribution transaction*.

Double spending

Double spending refers to the issuing of the same digital token more than once. This risk could exist because, unlike physical cash, a digital token consists of a digital file that could theoretically be duplicated or counterfeited.

Exchange

Transaction between a user and an *exchange point* for the purpose of converting *CBDC notes* into other types of money or vice versa.

Exchange point

Service operated by a professional actor that allows *exchanging CBDC notes* into other types of money or vice versa. May be hosted by commercial banks, be located within the *central bank* or take the form of top-up terminal provided by a private company.

Form factor

The form factor of the wallet is used to utilise the CBDC. In general, it is a combination of a piece of hardware - such as a mobile device or physical card - an app and a communication interface that supports various technologies.

Generation

In the course of a *transaction*, *CBDC notes* may be generated if CBDC notes of smaller value are aggregated. The generation of CBDC notes does not change the overall value of CBDC notes in circulation. Not to be confused with *creation*.

Issuance

Umbrella term covering *creation* and *distribution*.

Issuer

Entity controlled by the *central bank* which is responsible for *creating* and *distributing* CBDC notes and providing *updates* for CBDC notes.

Know your customer (KYC)

KYC involves the identification and verification of new and existing customers on the basis of money laundering requirements.

Locking

A wallet can be locked at the request of the user, e. g. in case of loss or theft. This locking can be lifted again.

Offline payments

The ability of the digital currency to be processed and used for payments without an internet connection.

Offline scenario

Scenario for the *validity check* in which a connection to the *confirmation authority* does not exist. Offline validity checks can only use information that is stored locally or in the *CBDC notes*.

Online scenario

Scenario for the *validity check* in which a connection to the *confirmation authority* exists and it can be queried for information.

Payment

Transfer of *CBDC notes* between two users.

Point-of-sale (POS) terminal

A POS terminal is generally a point of sale at which payment can be made. It is often understood to mean cashless payment. A POS can be fixed or run on a mobile device (mPOS).

Reactivating

With the reactivation of the wallet, the deactivation made by the user himself can be reversed in a controlled manner. Before the wallet can be fully used again, the update of the wallet software, corresponding certificates and connections as well as the CBDC notes are pending.

Recovery

Optional functionality allowing users to recover *CBDC notes* to which the possibility of access has been irrevocably lost. Recovery is performed by the *recovery authority*.

Recovery authority

Optional entity controlled by the *central bank* which is responsible for the *recovery process*.

Revocation

Process of withdrawing a *CBDC note* from circulation by permanently invalidating it. Revocation is performed by the *revocation authority* and decreases the overall value of *CBDC notes* in circulation. Not to be confused with *discarding*.

Revocation authority

Entity controlled by the *central bank* which is responsible for revoking *CBDC notes*.

Transaction

Umbrella term covering *payment*, *distribution* and *exchange*.

Update

To prevent *CBDC notes* from losing their security guarantees, it is necessary to update the security functionality in due time. To this end, an update process exists, in which the *issuer* provides updates for CBDC notes that are applied by the users.

Validity check

Before a *transaction* is executed, the validity of the involved *CBDC notes* is checked with respect to various aspects. The validity check is performed by querying the *confirmation authority* in an *online scenario* or (if applicable) based on information stored locally or in the CBDC notes in an *offline scenario*.

Wallet

Wallets are the central component of the CBDC infrastructure for the user. Here, the CBDC notes are not only stored securely, but also the use of the notes is initiated. A wallet is a physical medium consisting of hardware (device, card) or software (program, service).

List of abbreviations

AML	Anti-Money Laundering
CBDC	Central Bank Digital Currency
GDPR	General Data Protection Regulation
IDS	Intrusion Detection System
ISMS	Information Security Management System
KYC	Know Your Customer
TR	Technische Richtlinie (Technical Guideline)

Bibliography

- [1] Bundesamt für Sicherheit in der Informationstechnik, Technical Guideline BSI TR-03179-1: Central Bank Digital Currency – Part 1: Requirements on backend systems, available at <https://www.bsi.bund.de/TR>, 2024.
- [2] Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC, (General Data Protection Regulation), <https://eur-lex.europa.eu/eli/reg/2016/679/oj>, 27.04.2016.
- [3] Bundesamt für Sicherheit in der Informationstechnik, BSI TR-02102: Cryptographic Mechanisms, available at: <https://www.bsi.bund.de/EN/TR>.
- [4] Bundesamt für Sicherheit in der Informationstechnik, Technische Richtlinie BSI TR-02102-1: Kryptographische Verfahren: Empfehlungen und Schlüssellängen, available at <https://www.bsi.bund.de/TR>.
- [5] Bundesamt für Sicherheit in der Informationstechnik, Technische Richtlinie BSI TR-03107-1: Elektronische Identitäten und Vertrauensdienste im E-Government – Teil 1: Vertrauensniveaus und Mechanismen, available at <https://www.bsi.bund.de/TR>.
- [6] Bundesamt für Sicherheit in der Informationstechnik, Technische Richtlinie BSI TR-03116: Kryptographische Vorgaben für Projekte der Bundesregierung – Teil 4: Kommunikationsverfahren in Anwendungen, available at <https://www.bsi.bund.de/TR>.
- [7] Bundesamt für Sicherheit in der Informationstechnik, Technical Guideline TR-03119: Requirements for Smart Card Readers Supporting eID and eSign Based on Extended Access Control, available at <https://www.bsi.bund.de/TR>.
- [8] Bundesamt für Sicherheit in der Informationstechnik, BSI Technical Guideline TR-03151 Secure Element API (SE API), available at <https://www.bsi.bund.de/TR>.
- [9] Bundesamt für Sicherheit in der Informationstechnik, Technische Richtlinie BSI TR-03161-1: Anforderungen an Anwendungen im Gesundheitswesen - Teil 1: Mobile Anwendungen, available at <https://www.bsi.bund.de/TR>.
- [10] Bundesamt für Sicherheit in der Informationstechnik, Technische Richtlinie BSI TR-03161-2: Anforderungen an Anwendungen im Gesundheitswesen - Teil 2: Web-Anwendungen, available at <https://www.bsi.bund.de/TR>.
- [11] Bundesamt für Sicherheit in der Informationstechnik, BSI TR-03166: Technical Guideline for Biometric Authentication Components in Devices for Authentication, available at <https://www.bsi.bund.de/TR>.
- [12] Security Standards Council, Payment Card Industry (PCI) PIN Transaction Security (PTS). Device Testing and Approval Program Guide Version 1.9, available at https://pcisecuritystandards.org/documents/PTS_Program_Guide_v1-9_final.pdf, June 2020.
- [13] Security Standards Council, Payment Card Industry Data Security Standard (PCI DSS). Sicherheitsprüfungsverfahren, Version 1.1, available at https://www.pcisecuritystandards.org/pdfs/german_pci_audit_procedures_v1-1.pdf, September 2006.
- [14] Bundesamt für Sicherheit in der Informationstechnik, BSI-Standard 200-1: Information Security Management Systems (ISMS), available at <https://www.bsi.bund.de/EN/itgrundschutz>.
- [15] ISO/IEC JTC1/SC27, ISO/IEC 27001:2022 Information technology - Security techniques – Information security management systems requirements specification.